

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN



TIỂU LUẬN CUỐI KỲ
MÔN: BẢO MẬT TRONG IOT

HỆ THỐNG PHÁT HIỆN XÂM NHẬP CHO
MẠNG IOT

Lớp học phần	253INT441001
Giảng viên	Hồ Nhật Minh
Sinh viên	Nguyễn Quốc Kiệt
MSSV	231A010689
Mã đề tài	34
Hường đề tài	E
Link repo GitHub	https://github.com/quockiet031220-glitch/NguyenQuocKiet_BMIOT_Project
Ngày nộp	27/07/2026

TP. HỒ CHÍ MINH - 2026

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN



TIỂU LUẬN CUỐI KỲ
MÔN: BẢO MẬT TRONG IOT

HỆ THỐNG PHÁT HIỆN XÂM NHẬP CHO
MẠNG IOT

Lớp học phần	253INT441001
Giảng viên	Hồ Nhật Minh
Sinh viên	Nguyễn Quốc Kiệt
MSSV	231A010689
Mã đề tài	34
Hường đề tài	E
Link repo GitHub	https://github.com/quockiet031220-glitch/NguyenQuocKiet_BMIOT_Project
Ngày nộp	27/07/2026

TP. HỒ CHÍ MINH - 2026

LỜI CAM ĐOAN

Tôi xin cam đoan rằng đề tài "Hệ thống phát hiện xâm nhập cho mạng IoT" là kết quả của quá trình tìm hiểu, nghiên cứu và thực hiện của bản thân dưới sự hướng dẫn của giảng viên. Các nội dung trong báo cáo được xây dựng dựa trên kiến thức đã học, tài liệu tham khảo và quá trình triển khai, kiểm thử thực tế trong phạm vi đề tài.

Trong quá trình thực hiện báo cáo, tôi có sử dụng công cụ trí tuệ nhân tạo (AI) để hỗ trợ tìm hiểu kiến thức, gợi ý cách trình bày, diễn đạt nội dung và rà soát lỗi. Tuy nhiên, toàn bộ nội dung sau khi được AI hỗ trợ đều đã được tôi xem xét, chỉnh sửa và lựa chọn trước khi đưa vào báo cáo. Những phần sử dụng tài liệu từ các nguồn khác đều được trích dẫn theo quy định.

Tôi xin chịu hoàn toàn trách nhiệm về tính trung thực, chính xác của nội dung cũng như các số liệu, kết quả được trình bày trong báo cáo. Trường hợp có sai sót, bao gồm cả những thông tin hoặc số liệu do AI cung cấp nhưng chưa được kiểm chứng đầy đủ, tôi xin hoàn toàn chịu trách nhiệm và chấp nhận mọi hình thức xử lý theo quy định của nhà trường.

Tp.Hồ Chí Minh, ngày.....tháng.....năm.....

Sinh viên thực hiện

(Ký tên và ghi rõ họ tên)

NHẬN XÉT CỦA GIẢNG VIÊN HƯỚNG DẪN

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Tp.Hồ Chí Minh, ngày.....tháng.....năm.....

Giảng viên hướng dẫn

(Ký tên và ghi rõ họ tên)

MỤC LỤC

CHƯƠNG 1: TỔNG QUAN ĐỀ TÀI	1
1.1. Bối cảnh và lý do chọn đề tài	1
1.2. Vấn đề bảo mật IoT	1
1.3. Mục tiêu của đề tài.....	2
1.4. Đối tượng nghiên cứu	2
1.5. Sản phẩm và kết quả dự kiến	3
1.6. Cấu trúc báo cáo	3
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN.....	5
2.1. Kiến trúc hoặc bối cảnh kỹ thuật của hệ thống	5
2.2. Khái niệm bảo mật trực tiếp liên quan.....	5
2.2.1. Tài sản (<i>Asset</i>).....	5
2.2.2. Lỗ hổng (<i>Vulnerability</i>).....	5
2.2.3. Môi đe dọa (<i>Threat</i>)	5
2.2.4. Hệ thống phát hiện xâm nhập (<i>Intrusion Detection System - IDS</i>).....	6
2.2.5. IDS dựa trên chữ ký (<i>Signature-based IDS</i>)	6
2.2.6. IDS dựa trên hành vi (<i>Anomaly-based IDS</i>)	6
2.2.7. So sánh <i>Signature-based IDS</i> và <i>Anomaly-based IDS</i>	7
2.3. Trọng tâm theo hướng.....	8
2.4. Chuẩn, tài liệu và nguồn công cụ GitHub	9
2.5. Công trình hoặc giải pháp liên quan.....	9
2.6. Tiểu kết	13
CHƯƠNG 3: PHƯƠNG PHÁP VÀ THIẾT KẾ.....	14
3.1. Phương pháp thực hiện	14

3.2. Kiến trúc/mô hình và luồng dữ liệu	14
<i>3.2.1. Kiến trúc hệ thống</i>	<i>14</i>
<i>3.2.2. Phân vùng tin cậy của hệ thống.....</i>	<i>16</i>
<i>3.2.3. Dữ liệu nhạy cảm trong hệ thống</i>	<i>16</i>
3.4. Quy trình thực hiện	18
3.5. Tiêu chí đánh giá.....	18
CHƯƠNG 4: TRIỂN KHAI VÀ KẾT QUẢ	19
4.1. Chuẩn bị môi trường	19
4.2. Thành phần sản phẩm.....	19
4.3. Kịch bản thử nghiệm/đánh giá	22
4.4. Kết quả.....	23
4.5. Thảo luận & hạn chế	39
<i>4.5.1. Thảo luận kết quả.....</i>	<i>39</i>
<i>4.5.2. Hạn chế</i>	<i>39</i>
CHƯƠNG 5: ĐÁNH GIÁ BẢO MẬT	40
5.1. Tài sản và dữ liệu cần bảo vệ.....	40
5.2. Môi đe dọa và lỗ hổng.....	40
5.3. Ma trận rủi ro	41
5.4. Biện pháp giảm thiểu và ưu tiên.....	42
5.5. Rủi ro còn lại	43
CHƯƠNG 6: KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	44
6.1. Đối chiếu kết quả thực hiện với mục tiêu đề tài.....	44
6.2. Hạn chế	45
6.3. Hướng phát triển	45
TÀI LIỆU THAM KHẢO.....	46

PHỤ LỤC HÌNH ẢNH

Hình 3.1. Mô hình triển khai hệ thống phát hiện xâm nhập cho mạng IoT .	15
Hình 4.1. Môi trường thực nghiệm hệ thống trên VMware Workstation.....	23
Hình 4.2. Windows Client kiểm tra kết nối đến pfSense và Kali Linux	24
Hình 4.3. Kali Linux kiểm tra kết nối đến pfSense và Windows Client.....	24
Hình 4.4. Đăng nhập WebConfigurator của pfSense	25
Hình 4.5. Giao diện WebConfigurator pfSense	26
Hình 4.6. Trình hướng dẫn thiết lập ban đầu của pfSense	26
Hình 4.7. Giao diện quản trị chính của pfSense	27
Hình 4.8. Cài đặt gói Suricata IDS trên pfSense.....	27
Hình 4.9. Giao diện của Suricata sau khi cài đặt thành công.....	28
Hình 4.10. Cấu hình bộ luật và cơ chế cập nhật của Suricata IDS	28
Hình 4.11. Cấu hình bộ luật và cơ chế cập nhật của Suricata IDS	29
Hình 4.12. Cập nhật bộ luật phát hiện xâm nhập của Suricata	29
Hình 4.13. Thiết lập giao diện LAN cho Suricata	30
Hình 4.14. Giao diện Interface Lan sau khi được thiết lập	30
Hình 4.15. Giao diện lựa chọn nhóm luật phát hiện xâm nhập cho Suricata	31
Hình 4.16. Lựa chọn các nhóm luật phát hiện xâm nhập của Suricata.....	31
Hình 4.17. Khởi động Suricata trên giao diện LAN	32
Hình 4.18. Giao diện trang web Node.js	32
Hình 4.19. Kiểm tra môi trường Node.js trên Windows Client	33
Hình 4.20. Cài đặt Node-RED bằng npm	33
Hình 4.21. Khởi động dịch vụ Node-RED trên Windows Client.....	33

Hình 4.22. Giao diện quản lý Node-RED trên Windows Client	34
Hình 4.23. Cấu hình luồng mô phỏng dịch vụ cảm biến IoT trên Node-RED	35
Hình 4.24. Kiểm tra hoạt động của dịch vụ cảm biến IoT trên Node-RED ..	35
Hình 4.25. Kết quả truy cập dịch vụ cảm biến IoT từ máy Kali Linux.....	36
Hình 4.26. Tạo lưu lượng HTTP từ máy Kali Linux đến dịch vụ Node-RED	36
Hình 4.27. Kết quả quét cổng dịch vụ Node-RED bằng Nmap	37
Hình 4.28. Giao diện trang cảnh báo	38
Hình 4.29. Suricata IDS phát hiện hoạt động quét cổng từ máy Kali Linux	38

PHỤC LỤC BẢNG BIỂU

Bảng 1.1. Bảng đối chiếu mục tiêu và đầu ra	4
Bảng 2.1. So sánh Signature-based IDS và Anomaly-based IDS	7
Bảng 2.2. Các đặc trưng được sử dụng trong quá trình phát hiện	8
Bảng 2.3. Công cụ và nguồn GitHub.....	9
Bảng 2.4. So sánh các giải pháp.....	11
Bảng 3.1. Thành phần, công cụ và dữ liệu.....	17
Bảng 3.2. Quy trình thực hiện	18
Bảng 3.3. Tiêu chí đánh giá.....	18
Bảng 4.1. Cấu hình mạng	19
Bảng 4.2. Thành phần sản phẩm.....	19
Bảng 4.3. Kịch bản thử nghiệm/đánh giá	22
Bảng 4.4. Bảng tổng hợp	39
Bảng 5.1. Tài sản và dữ liệu cần bảo vệ	40
Bảng 5.2. Môi đe dọa và lỗ hổng.....	40
Bảng 5.3. Ma trận rủi ro.....	42
Bảng 5.4. Biện pháp giảm thiểu và ưu tiên.....	42
Bảng 6.1. Bảng đối chiếu kết quả thực hiện với mục tiêu đề tài.....	44

BẢNG CHÚ THÍCH TỪ VIẾT TẮT VÀ ANH – VIỆT

Từ viết tắt	Tiếng Anh	Tiếng Việt
AD	Active Directory	Dịch vụ thư mục Active Directory
API	Application Programming Interface	Giao diện lập trình ứng dụng
CE	Community Edition	Phiên bản Cộng đồng
CPU	Central Processing Unit	Bộ xử lý trung tâm
DNS	Domain Name System	Hệ thống phân giải tên miền
DoS	Denial of Service	Tấn công từ chối dịch vụ
ET Open	Emerging Threats Open	Bộ luật phát hiện mã nguồn mở của Emerging Threats
HTTP	Hypertext Transfer Protocol	Giao thức truyền tải siêu văn bản
HTTPS	Hypertext Transfer Protocol Secure	Giao thức truyền tải siêu văn bản bảo mật
ICMP	Internet Control Message Protocol	Giao thức điều khiển thông điệp Internet
IDS	Intrusion Detection System	Hệ thống phát hiện xâm nhập
IP	Internet Protocol	Giao thức Internet
IoT	Internet of Things	Internet vạn vật
JSON	JavaScript Object Notation	Định dạng trao đổi dữ liệu JSON
LAN	Local Area Network	Mạng cục bộ
NAT	Network Address Translation	Chuyển đổi địa chỉ mạng
Nmap	Network Mapper	Công cụ quét và lập bản đồ mạng
OISF	Open Information Security Foundation	Tổ chức Phát triển An ninh Thông tin Mã nguồn mở
OS	Operating System	Hệ điều hành
pfSense	Packet Filter Sense	Hệ điều hành tường lửa mã nguồn mở dựa trên FreeBSD
REST	Representational State Transfer	Kiến trúc dịch vụ web REST
TCP	Transmission Control Protocol	Giao thức điều khiển truyền vận
TLS	Transport Layer Security	Giao thức bảo mật tầng truyền tải
URL	Uniform Resource Locator	Địa chỉ tài nguyên trên Internet
VM	Virtual Machine	Máy ảo
VMware	VMware Workstation	Phần mềm tạo và quản lý máy ảo
WAN	Wide Area Network	Mạng diện rộng

CHƯƠNG 1: TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Trong bối cảnh hiện tại, các thiết bị Internet vạn vật (IoT) đã được áp dụng hầu hết trong các lĩnh vực như y tế, công nghiệp, nông nghiệp, nhà thông minh và giao thông. Việc thực hiện kết nối nhiều thiết bị vào mạng giúp chúng ta quản lý dễ dàng hơn nhưng cũng tồn tại nhiều rủi ro về an toàn thông tin. Theo OWASP (2024) các thiết bị IoT tồn tại nhiều rủi ro về bảo mật như cấu hình không an toàn, mật khẩu yếu và thiếu cơ chế cập nhật bảo mật.

Hiện thực cho thấy nhiều cuộc tấn công mạng với quy mô lớn đã dùng các thiết bị IoT để phát tán mã độc, đánh cắp dữ liệu, tấn công từ chối dịch vụ (DDoS). Với việc sử dụng tường lửa truyền thống vẫn chưa đủ để phát hiện các hành vi bất thường diễn ra trong mạng IoT. Theo National Institute of Standards and Technology (NIST), việc triển khai cơ chế giám sát và phát hiện xâm nhập là một trong những giải pháp quan trọng để nâng cao sự bảo vệ của hệ thống IoT trước các mối đe dọa về bảo mật.

Xuất phát từ những vấn đề trên, đề tài “Hệ thống phát hiện xâm nhập cho mạng IoT” được triển khai với mục tiêu xây dựng mô hình mạng IoT mô phỏng kết hợp với hệ thống phát hiện xâm nhập (IDS) nhằm theo dõi lưu lượng mạng và đánh giá các hành vi bất thường để nhận biết sớm các dấu hiệu tấn công.

1.2. Vấn đề bảo mật IoT

Trong môi trường IoT, các tài sản cần được bảo vệ bao gồm thiết bị IoT, dữ liệu truyền trên mạng, tính sẵn sàng của hệ thống và các máy chủ. Do khả năng bảo mật còn hạn chế và số lượng thiết bị quá lớn nên dễ trở thành mục tiêu của các cuộc tấn công như là dò mật khẩu, khai thác lỗ hổng, quét cổng, phát tán mã độc hoặc từ chối dịch vụ.

Các hành vi bất thường nếu không được phát hiện kịp thời, kẻ tấn công sẽ có thể chiếm quyền điều khiển thiết bị, làm gián đoạn hoạt động của toàn bộ hệ thống. Song

song với đó, tồn tại nhiều mô hình mạng IoT nhỏ chưa triển khai các cơ chế giám sát và phát hiện xâm nhập, dẫn đến việc khó nhận dạng các cuộc tấn công ngay từ giai đoạn đầu.

Đề tài “ Hệ thống phát hiện xâm nhập cho mạng IoT” mô phỏng kết hợp hệ thống phát hiện xâm nhập giám sát lưu lượng mạng, phát hiện các hoạt động bất thường và hỗ trợ người quản trị đưa ra biện pháp xử lý phù hợp hơn.

1.3. Mục tiêu của đề tài

Đề tài này tập trung vào các mục tiêu như sau:

- Mục tiêu đầu tiên: thiết kế mô hình IDS phù hợp với môi trường mạng IoT, xác định vị trí triển khai hệ thống giám sát trong kiến trúc mạng.
- Mục tiêu thứ hai: nghiên cứu và so sánh hai phương pháp phát hiện xâm nhập phổ biến là Signature-based IDS và Anomaly-based IDS, từ đó chọn ra phương pháp với mô hình nghiên cứu.
- Mục tiêu thứ ba: cấu hình và áp dụng các luật (rule) phát hiện phù hợp để giám sát lưu lượng IoT và phát hiện các hành vi bất thường.
- Mục tiêu thứ tư: Đánh giá kết quả hoạt động của hệ thống phát hiện xâm nhập thông qua các cảnh báo, nhật ký sự kiện và kết quả thực nghiệm.

1.4. Đối tượng nghiên cứu

Đề tài tập trung vào các đối tượng nghiên cứu chính sau:

- Hệ thống phát hiện xâm nhập mạng (IDS).
- pfSense Firewall.
- Suricata IDS.
- Mạng IoT mô phỏng.
- Vmware Workstation.
- Kali Linux và Windows.

Phạm vi nghiên cứu

Đề tài được thực hiện trên máy tính cá nhân dùng Vmware Workstation để triển khai. Dữ liệu sẽ được trao đổi qua mạng nội bộ (LAN) giữa các máy ảo nhằm phục vụ quá trình nghiên cứu và đánh giá hệ thống phát hiện xâm nhập. Các kịch bản tấn công và dữ liệu được xây để thử nghiệm, không ảnh hưởng đến hệ thống thực tế.

Giới hạn an toàn

Đề tài không triển khai trên các thiết bị IoT thực tế, không thực hiện tấn công với các hệ thống của tổ chức hoặc cá nhân khác, không khai thác trái phép các dịch vụ trên Internet và chỉ sử dụng các công cụ kiểm thử trong phạm vi thí nghiệm phục vụ mục đích học tập.

1.5. Sản phẩm và kết quả dự kiến

Đề tài dự kiến sẽ đạt được những các sản phẩm như sau:

Mô hình mạng IoT mô phỏng sử dụng pfSense, Suricata IDS, Kali Linux, Node-RED và Windows Client; Bộ Rule được sử dụng trong Suricata để nhận biết các hành vi bất thường trên mạng IoT; Lưu lượng (Dataset) và các kịch bản mô phỏng phục vụ kiểm thử hệ thống phát hiện xâm nhập; Nhật ký cảnh báo (Alert Log) và bảng tổng hợp kết quả phát hiện của hệ thống; Tài liệu hướng dẫn triển khai và tái hiện mô hình phục vụ mục đích học tập và nghiên cứu.

1.6. Cấu trúc báo cáo

Cấu trúc của bài báo cáo gồm sáu chương:

Chương 1. Trình bày tổng quan về đề tài, bối cảnh nghiên cứu, mục tiêu, phạm vi và sản phẩm dự kiến. Chương 2 trình bày cơ sở lý thuyết liên quan đến mạng IoT, an toàn thông tin, hệ thống phát hiện xâm nhập và các công nghệ được sử dụng. Chương 3 mô tả quá trình thiết kế và xây dựng mô hình thực nghiệm. Chương 4 trình bày quá trình triển khai, thực hiện các kịch bản kiểm thử và kết quả đạt được. Chương 5 đánh giá kết quả thực nghiệm, phân tích ưu điểm và hạn chế của hệ thống. Chương 6 đưa ra kết luận và định hướng phát triển trong tương lai.

Bảng 1.1. Bảng đối chiếu mục tiêu và đầu ra

Mục tiêu (MT)	Đầu ra tương ứng	Cách kiểm chứng	Chương trình bày
MT-01	Mô hình kiến trúc IDS cho mạng IoT	Sơ đồ kiến trúc và mô tả hệ thống	Chương 3
MT-02	Phân tích cơ sở lý thuyết về IDS và lựa chọn Suricata	Trình bày đặc điểm của Signature-based IDS và Anomaly-based IDS, đồng thời giải thích lý do lựa chọn Suricata	Chương 2
MT-03	Xây dựng mô hình và triển khai hệ thống IDS	Cấu hình pfSense, Suricata, Node-RED và kịch bản kiểm thử	Chương 3, Chương 4
MT-04	Đánh giá khả năng phát hiện của hệ thống IDS	Kết quả kiểm thử, log cảnh báo Suricata và phân tích kết quả	Chương 5

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc hoặc bối cảnh kỹ thuật của hệ thống

Mô hình gồm các thành phần chính như máy tấn công (Kali Linux), tường lửa pfSense tích hợp hệ thống phát hiện xâm nhập Suricata IDS, máy chủ người dùng Windows và một nút mô phỏng thiết bị IoT hoặc ứng dụng Node-RED.

2.2. Khái niệm bảo mật trực tiếp liên quan

2.2.1. Tài sản (*Asset*)

Theo OWASP IoT Security Testing Guide (ISTG), tài sản là các thành phần có giá trị cần được bảo vệ trong hệ thống IoT. Ở đề tài này, tài sản là các thiết bị IoT được mô phỏng bằng Node-RED, hệ thống pfSense tích hợp Suricata, máy người dùng và dữ liệu truyền trên mạng.

2.2.2. Lỗ hổng (*Vulnerability*)

Lỗ hổng (*Vulnerability*) là những điểm yếu tồn tại trong thiết bị, phần mềm hoặc cấu hình hệ thống có thể bị khai thác để thực hiện các hành vi tấn công. Theo OWASP IoT Security Verification Standard (ISVS), việc phát hiện và khắc phục lỗ hổng là một trong những yêu cầu quan trọng nhằm đảm bảo an toàn cho hệ thống IoT (OWASP Foundation, 2024).

Trong mô hình nghiên cứu của đề tài, lỗ hổng có thể xuất hiện do cấu hình chưa phù hợp, thiếu cơ chế giám sát lưu lượng hoặc mở các dịch vụ không cần thiết. Chính vì vậy, hệ thống IDS được triển khai nhằm hỗ trợ phát hiện sớm các dấu hiệu bất thường có liên quan đến việc khai thác những lỗ hổng này.

2.2.3. Môi đe dọa (*Threat*)

Theo OWASP ISTG, môi đe dọa (*Threat*) là các hành động hoặc sự kiện có khả năng làm ảnh hưởng đến tính an toàn của hệ thống IoT, chẳng hạn như truy cập trái phép, quét công, khai thác lỗ hổng hoặc tạo lưu lượng bất thường (OWASP Foundation, 2024).

Đề tài sẽ mô phỏng các mối đe dọa để kiểm thử khả năng phát hiện xâm nhập của IDS. Ngoài ra đề tài còn đề cập đến một số kịch bản dự kiến bao gồm quét cổng, tạo lưu lượng bất thường từ máy Kali Linux, đăng nhập sai nhiều lần.

2.2.4. Hệ thống phát hiện xâm nhập (Intrusion Detection System - IDS)

Hệ thống phát hiện xâm nhập (IDS) là giải pháp giám sát lưu lượng mạng hoặc hoạt động của hệ thống nhằm phát hiện các dấu hiệu tấn công và gửi cảnh báo đến người quản trị. Theo OWASP ISTG, IDS đóng vai trò quan trọng trong việc phát hiện sớm các hành vi bất thường để hỗ trợ quá trình ứng phó sự cố (OWASP Foundation, 2024).

Suricata được thiết lập làm hệ thống IDS để phân tích gói tin theo thời gian thực, đối chiếu với tập luật (Rule) và tạo cảnh báo khi phát hiện hành vi đáng ngờ. IDS đóng vai trò hỗ trợ giám sát và cảnh báo để nâng cao khả năng bảo vệ hệ thống.

2.2.5. IDS dựa trên chữ ký (Signature-based IDS)

IDS dựa trên chữ ký (Signature-based IDS) là phương pháp phát hiện xâm nhập bằng cách so sánh lưu lượng mạng với các mẫu tấn công hoặc tập luật đã được xây dựng trước. Khi lưu lượng trùng khớp với một chữ ký trong cơ sở dữ liệu, hệ thống sẽ sinh cảnh báo (OWASP Foundation, 2024).

Phương pháp này sẽ có ưu điểm phát hiện nhanh và chính xác đối với các kiểu tấn công đã biết, tỷ lệ cảnh báo sai thường thấp. Nhưng đi song với đó là những nhược điểm như khó phát hiện các mối đe dọa mới hoặc các biến thể chưa có trong cơ sở dữ liệu chữ ký. Trong đề tài, Suricata sử dụng các tập luật để nhận diện một số hành vi như quét cổng, truy cập trái phép hoặc lưu lượng bất thường.

2.2.6. IDS dựa trên hành vi (Anomaly-based IDS)

Khác với Signature-based IDS, IDS dựa trên hành vi (Anomaly-based IDS) phát hiện xâm nhập bằng cách xây dựng mô hình hoạt động bình thường của hệ thống và cảnh báo khi phát hiện sự sai lệch so với mô hình đó. Theo OWASP ISVS, phương pháp này có khả năng nhận diện các hành vi bất thường ngay cả khi chưa có chữ ký tấn công tương ứng (OWASP Foundation, 2024).

Ưu điểm của Anomaly-based IDS là có thể phát hiện các cuộc tấn công mới hoặc các biến thể chưa từng xuất hiện. Ngược lại Anomaly-based IDS có tỉ lệ cảnh báo sai cao hơn do không xác định được ranh giới giữa hoạt động bình thường và bất thường. Trong phạm vi đề tài, phương pháp này được nghiên cứu để so sánh với Signature-based IDS nhằm đánh giá ưu điểm, hạn chế và khả năng áp dụng trong môi trường mạng IoT. Chuẩn, công cụ và nguồn GitHub chính

2.2.7. So sánh Signature-based IDS và Anomaly-based IDS

Để chọn ra một phương pháp phù hợp với mục tiêu của đề tài, cần so sánh hai cơ chế phổ biến là Signature-based IDS và Anomaly-based IDS.

Bảng 2.1. So sánh Signature-based IDS và Anomaly-based IDS

Tiêu chí	Signature-based IDS	Anomaly-based IDS
Nguyên lý phát hiện	Phát hiện bằng cách so sánh lưu lượng mạng với các chữ ký hoặc tập luật đã được xây dựng trước.	Phát hiện dựa trên sự sai lệch so với mô hình hoạt động bình thường của hệ thống.
Khả năng phát hiện tấn công đã biết	Cao, phát hiện nhanh và chính xác đối với các mẫu tấn công đã có chữ ký.	Có thể phát hiện nhưng phụ thuộc vào mô hình hành vi được xây dựng.
Khả năng phát hiện tấn công mới	Hạn chế do chưa có chữ ký nhận diện.	Có khả năng phát hiện các cuộc tấn công mới hoặc các biến thể chưa có chữ ký.
Tỷ lệ cảnh báo giả (False Positive)	Thường thấp do chỉ cảnh báo khi lưu lượng khớp với chữ ký đã biết.	Có thể cao hơn do khó xác định chính xác ranh giới giữa hành vi bình thường và bất thường.
Yêu cầu triển khai	Chỉ cần cập nhật tập luật thường xuyên để duy trì khả năng phát hiện.	Cần xây dựng mô hình hành vi hoặc dữ liệu huấn luyện phù hợp với môi trường triển khai.
Mức độ phù hợp với đề tài	Phù hợp với đề tài vì Suricata hoạt động theo cơ chế phát hiện dựa trên chữ ký, dễ triển khai và đánh giá trong môi trường mô phỏng.	Chỉ được nghiên cứu ở mức lý thuyết và so sánh, chưa triển khai trong phạm vi của đề tài.

Trong phạm vi đề tài, nhóm lựa chọn triển khai Suricata IDS. Đây là hệ thống phát hiện xâm nhập dựa trên chữ ký (Signature-based IDS), sử dụng tập luật để nhận diện các mẫu tấn công đã biết. Giải pháp này phù hợp với quy mô mô hình thực nghiệm, dễ triển khai và đáp ứng mục tiêu đánh giá khả năng phát hiện các hành vi quét cổng và truy cập bất thường trong mạng IoT.

2.3. Trọng tâm theo hướng

Đề tài “Hệ thống phát hiện xâm nhập cho mạng IoT” thuộc hướng E, tập trung vào việc giám sát lưu lượng mạng và phát hiện các dấu hiệu bất thường trong môi trường IoT thông qua hệ thống IDS. Trong đó pfSense đóng vai trò là cổng mạng và Suricata IDS được triển khai để giám sát các gói tin đi qua mạng LAN, Node-RED được dùng để tạo lưu lượng HTTP.

Suricata hoạt động dựa trên tập luật, khi có lưu lượng mạng khớp với chữ ký tấn công đã được định nghĩa trong bộ luật Emerging Threats, hệ thống sẽ phát cảnh báo để quản trị viên có thể theo dõi và đánh giá nguy cơ. Để phục vụ quá trình đánh giá, đề tài tập trung vào các lưu lượng như giao thức sử dụng, cổng dịch vụ thời gian xảy ra sự kiện, nội dung cảnh báo do Suricata sinh ra, địa chỉ IP đích và IP nguồn.

Bảng 2.2. Các đặc trưng được sử dụng trong quá trình phát hiện

Đặc trưng	Ý nghĩa
Địa chỉ IP nguồn	Thiết bị khởi tạo lưu lượng
Địa chỉ IP đích	Thiết bị nhận lưu lượng
Giao thức	TCP/HTTP
Cổng dịch vụ	Cổng 1880 (Node-RED)
Loại cảnh báo	Signature của Suricata
Thời gian	Thời điểm phát hiện sự kiện

2.4. Chuẩn, tài liệu và nguồn công cụ GitHub

Bảng 2.3. Công cụ và nguồn GitHub

STT	Nguồn/Repo	URL/Phiên bản	Phần đã sử dụng	Truy cập
1	OWASP IoT Security Testing Guide (ISTG)	https://github.com/OWASP/owasp-istg	Tham khảo quy trình kiểm thử bảo mật, nhận diện tài sản, mối đe dọa và xây dựng phương pháp phát hiện.	14/07/2026
2	OWASP IoT Security Verification Standard (ISVS)	https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS	Tham khảo tiêu chuẩn đánh giá và xác minh các yêu cầu bảo mật cho hệ thống IoT.	14/07/2026
3	Node-RED	https://github.com/node-red/node-red	Mô phỏng thiết bị IoT và tạo lưu lượng phục vụ kiểm thử.	14/07/2026
4	Suricata	https://github.com/OISF/suricata	Tham khảo cơ chế hoạt động của IDS và cấu trúc Rule phát hiện.	14/07/2026
5	pfSense CE	https://github.com/pfsense/pfsense	Tham khảo cấu hình gateway và tích hợp Suricata trong mô hình nghiên cứu.	14/07/2026

2.5. Công trình hoặc giải pháp liên quan

Nghiên cứu của Lucas Ferreira Lima (2026): Vấn đề nghiên cứu: Sự phát triển bùng nổ của thiết bị IoT mở rộng bề mặt tấn công mạng, đòi hỏi phải đánh giá và tìm ra giải pháp IDS mã nguồn mở tối ưu nhất (giữa Snort, Suricata và Zeek) để bảo vệ hạ tầng. Phương pháp nghiên cứu: Sử dụng framework Dalton để chạy container Docker cô lập nhằm phân tích ngoại tuyến (offline) tệp PCAP từ bộ dữ liệu Edge-IIoTset. Thu thập số liệu hiệu năng (CPU, RAM) bằng lệnh docker stats và chuẩn hóa nhật ký sự kiện bằng các tập lệnh phân tích (parser) viết bằng Python. Đối tượng và phạm vi nghiên cứu: Phân tích lưu lượng mạng độc hại (DDoS, Port Scanning, Ransomware, Web injection) đi qua hệ thống mạng giả lập. Kết quả: Snort đạt độ

chính xác cao nhất (91,5% precision) nhưng bỏ sót các cuộc tấn công phức tạp. Zeek đạt tỷ lệ phát hiện cao nhất (94,0% recall) và siêu nhẹ (CPU < 2%, RAM < 70MB). Suricata đạt sự cân bằng tốt nhất (F1-Score 77,6%) và chống chịu tốt trước tấn công volumetric, nhưng tốn phần cứng nhất (đỉnh điểm CPU lên đến 1318% và RAM 1,9 GB).

Giải pháp SUKRY (2022) của Irfan Syamsuddin & Omar Mohammed Barukab: Vấn đề nghiên cứu: Thuật toán học máy k-Nearest Neighbor (kNN) hoạt động rất kém và tốn tài nguyên tính toán khi xử lý các bộ dữ liệu IoT lớn (như Bot-IoT). Đồng thời thiếu các nghiên cứu triển khai IDS thực tế trên phần cứng giá rẻ như Raspberry Pi. Phương pháp nghiên cứu: Thử nghiệm trong môi trường phần mềm Rapidminer để đánh giá kNN kết hợp với 3 kỹ thuật chọn lọc đặc trưng khác nhau: Information Gain (IG), Forward Selection (FS) và Backward Elimination (BE). Đối tượng và phạm vi nghiên cứu: Phân loại 5 nhóm lưu lượng (DDoS, Reconnaissance, DoS, Normal, Theft) từ bộ dữ liệu Bot-IoT và triển khai mô hình tối ưu lên Suricata chạy trên hệ điều hành Raspbian. Kết quả: Sự kết hợp kNN-FS (Forward Selection) cho kết quả xuất sắc nhất với độ chính xác 99,89%, F1-Score 98,78% và thời gian thực thi chỉ mất 7 giây. Mô hình này được đóng gói thành giải pháp IDS thông minh mang tên SUKRY chạy thực tế trên Raspberry Pi.

Giải pháp SurIoT (2026) của Lerina Aversano et al: Vấn đề nghiên cứu: Các thiết bị y tế kết nối (IoMT) sử dụng giao thức truyền tin hạng nhẹ (như MQTT) rất dễ bị tấn công, nhưng các giải pháp học máy (ML/DL) bảo vệ chúng lại quá nặng, thiếu tính minh bạch ("hộp đen") và không tương thích trực tiếp với các bộ lọc gói tin thời gian thực. Phương pháp nghiên cứu: Sử dụng TShark để trích xuất các đặc trưng phi trạng thái (stateless) ở tầng IP/TCP từ tệp PCAP. Huấn luyện mô hình Cây quyết định (Decision Tree) để tìm ra ranh giới phân loại rõ ràng, sau đó dịch tự động 1:1 các ranh giới này thành bộ luật tĩnh của Suricata và Snort. Đối tượng và phạm vi nghiên cứu: Bảo vệ lưu lượng giao thức MQTT trong mạng y tế IoMT (sử dụng cả dữ liệu giả lập từ IoT-Flock lẫn bộ dữ liệu thực tế IoMT-Traffic-Data). Kết quả: Các luật Suricata được tạo ra tự động đạt F1-Score 100% với dữ liệu Crafted, 99,77% với DoS Flood, và 99,85% trên bộ dữ liệu IoMT. Đặc biệt, công cụ Suricata thực thi các luật này

nhANH hơn gấp 31 đến 57 lần so với việc chạy toàn bộ quy trình suy luận học máy (ML pipeline) truyền thống mà không hề bị giảm độ chính xác phát hiện.

Nghiên cứu về Zeek của Samsul Huda et al. (2025): Vấn đề nghiên cứu: Khả năng hoạt động và mức độ tiêu thụ tài nguyên của Zeek IDS tại các mạng IoT nông nghiệp (nơi có tài nguyên hạn chế, kết nối chập chờn và môi trường khắc nghiệt) chưa được khám phá sâu. Phương pháp nghiên cứu: Thiết lập Zeek trong môi trường ảo hóa VirtualBox giả lập Raspberry Pi. Tiến hành phân tích cả ngoại tuyến (file PCAP của Stratosphere Laboratory) lẫn mô phỏng tấn công thời gian thực bằng Hydra (Brute-force SSH) và Hping3 (DDoS). Đối tượng và phạm vi nghiên cứu: Lưu lượng mạng IoT nông nghiệp điều khiển hệ thống tưới tiêu và cảm biến đất. Kết quả: Bộ nhớ của Zeek duy trì ổn định dưới 20% khi bị tấn công. Khi xảy ra DDoS, CPU của Zeek bị đẩy lên đỉnh điểm 120% nhưng vẫn giữ được băng thông tốt và tỷ lệ mất gói cực thấp (0,000186%). Tấn công Brute-force có tác động mạnh nhất đến chất lượng dịch vụ mạng, làm tăng độ trễ (delay) lên 2,159 ms.

Bảng so sánh ngắn các giải pháp liên quan:

Bảng 2.4. So sánh các giải pháp

Tiêu chí so sánh	Nghiên cứu của Lucas F. Lima (2026)	Giải pháp SUKRY (2022)	Giải pháp SurIoT (2026)	Nghiên cứu của Samsul Huda (2025)	Đề tài: Hệ thống phát hiện xâm nhập cho mạng IoT
Công cụ IDS chính	Snort, Suricata, Zeek	Suricata	Suricata, Snort	Zeek	Suricata
Giao thức mạng đích	TCP, UDP, IP chung	TCP/IP, Botnet chung	MQTT, TCP	TCP, UDP, ICMP, SSH	HTTP, MQTT (giả lập), TCP/IP
Môi trường triển khai	Dalton (Docker trên Linux)	Raspberry Pi thực tế	Trình dịch offline / Replay PCAP	VirtualBox (giả lập Raspberry Pi OS)	VMware Workstation (pfSense tích hợp Suricata)
Cách thức phát hiện	Dựa trên chữ ký (Emerging)	Học máy lai (kNN-FS) chạy	Luật tỉnh dịch từ mô hình Cây quyết định	Phân tích hành vi & kiểm tra giao	Luật phát hiện tĩnh (Signature-based)

	Threats ruleset)	qua OPNIDS		thức qua Script	Rules) tự viết
Nguồn dữ liệu / Lab	Dataset Edge-IIoTset tĩnh	Dataset Bot-IoT tĩnh	Dataset sinh từ IoT-Flock & IoMT-Traffic-Data	Dataset Stratosphere & Tấn công trực tiếp (Hydra, Hping3)	Tấn công thời gian thực (Live Traffic) từ Kali Linux đến Node-RED

Kế thừa

Kế thừa các Tiêu chuẩn Bảo mật Quốc tế: kế thừa trực tiếp các định nghĩa về tài sản (Asset), mối đe dọa (Threat), lỗ hổng (Vulnerability) và quy trình kiểm thử từ hai khung tài liệu chuẩn của OWASP là OWASP IoT Security Testing Guide (ISTG) và OWASP IoT Security Verification Standard (ISVS).

Kế thừa Kiến trúc và Công nghệ Core: Lựa chọn Suricata làm công cụ phát hiện xâm nhập mạng (NIDS) chính. Quyết định này hoàn toàn đồng nhất với kết luận của Lucas Ferreira Lima (2026) rằng Suricata là giải pháp cân bằng và mạnh mẽ nhất cho các trạm cổng (Gateways), cũng như kế thừa định dạng viết luật (Rule syntax) tiêu chuẩn của Suricata.

Phương pháp Mô phỏng Thiết bị: Sử dụng phần mềm Node-RED làm công cụ giả lập dữ liệu cảm biến IoT để phát ra lưu lượng mạng phục vụ kiểm thử — đây là một phương pháp giả lập chuẩn được khuyến nghị rộng rãi trong cộng đồng bảo mật IoT.

Cải tiến và điều chỉnh thực tiễn

Tích hợp pfSense Firewall và Suricata (Active Perimeter Defense):

Trước đó: Các nghiên cứu như của Lucas F. Lima chỉ chạy Suricata trên Dalton/Docker để phân tích log tĩnh hoặc SurIoT chỉ chạy dịch mã offline.

Cải tiến: đề tài đã tích hợp trực tiếp Suricata chạy song song trên pfSense CE đóng vai trò là một cổng Gateway Firewall biên thực tế. Hệ thống này vừa thực hiện định

tuyên, vừa lọc tường lửa, vừa thực thi phát hiện xâm nhập thời gian thực ngay tại chốt chặn biên của mô hình mạng LAN nội bộ.

Tối giản hóa tài nguyên (Cân bằng giữa Bảo mật và Phần cứng IoT):

Trước đó: Các nghiên cứu ML/DL như kNN-FS của SUKRY hay Cây quyết định của SurIoT đều yêu cầu các công cụ trung gian (TShark, NumPy, thư viện Python) hoạt động rất nặng và tạo độ trễ lớn. Ngay cả Suricata nguyên bản cũng ngốn tài nguyên rất lớn (đỉnh CPU 1318% trong bài test của Lima).

Cải tiến: đề tài đã tối giản hóa hệ thống bằng cách tự cấu hình và áp dụng các luật phát hiện tĩnh (Signature-based Rules) đơn giản. Sự điều chỉnh này giúp hệ thống hoạt động vô cùng nhẹ nhàng, không gây quá tải tài nguyên của CPU/RAM, triệt tiêu độ trễ của các mô hình học máy, cực kỳ thích hợp với thực tế phần cứng nghèo nàn của các router/gateway IoT cỡ nhỏ.

Xây dựng Live Lab động thay vì Dataset tĩnh:

Đa số các giải pháp liên quan đều nạp các file PCAP lưu lượng ghi sẵn từ các bộ dữ liệu có sẵn (như Bot-IoT, Edge-IIoTset).

Cải tiến: đề tài xây dựng một môi trường động chạy thời gian thực (Live Traffic) trên VMware Workstation. Máy tấn công Kali Linux trực tiếp bắn các gói tin quét cổng (Port scanning), hay tạo lưu lượng bất thường đến các máy ảo Windows/Node-RED. Suricata trên pfSense lập tức bắt gói tin trực tiếp trên đường truyền và sinh Alert Log động ngay lúc đó. Điều này đem lại tính thực quan cao hơn rất nhiều cho việc huấn luyện và học tập thực tế.

2.6. Tiểu kết

Ở chương 2 đã trình bày các cơ sở lý thuyết phục vụ cho đề tài, gồm những kiến trúc của hệ thống IoT, trọng tâm hướng E, các khái niệm bảo mật liên qua, các công cụ sử dụng và các công trình nghiên cứu liên quan. Những nội dung này là nền tảng để xây dựng mô hình thực nghiệm, triển khai hệ thống phát hiện xâm nhập bằng Suricata IDS và đánh giá kết quả ở các chương tiếp theo.

CHƯƠNG 3: PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Đề tài sử dụng phương pháp nghiên cứu kết hợp gồm mô phỏng, thực nghiệm trong môi trường ảo hóa, mô hình mối đe dọa, phân tích rủi ro và kiểm thử bảo mật.

Mô phỏng: đề tài xây dựng trong môi trường ảo hóa bằng VMware Workstation, các máy ảo đảm nhiệm các vai trò khác nhau gồm Windows Client, pfSense tích hợp Suricata, Kali Linux và Node-RED phục vụ cho việc kiểm thử.

Thực nghiệm trong Lab: các thành phần sẽ được kết nối cùng mạng Lan, Windows đóng vai trò là người dùng hợp lệ thực hiện việc gửi và nhận dữ liệu mô phỏng qua hệ thống. pfSense kết hợp Suricata giám sát lưu lượng đi qua hệ thống.

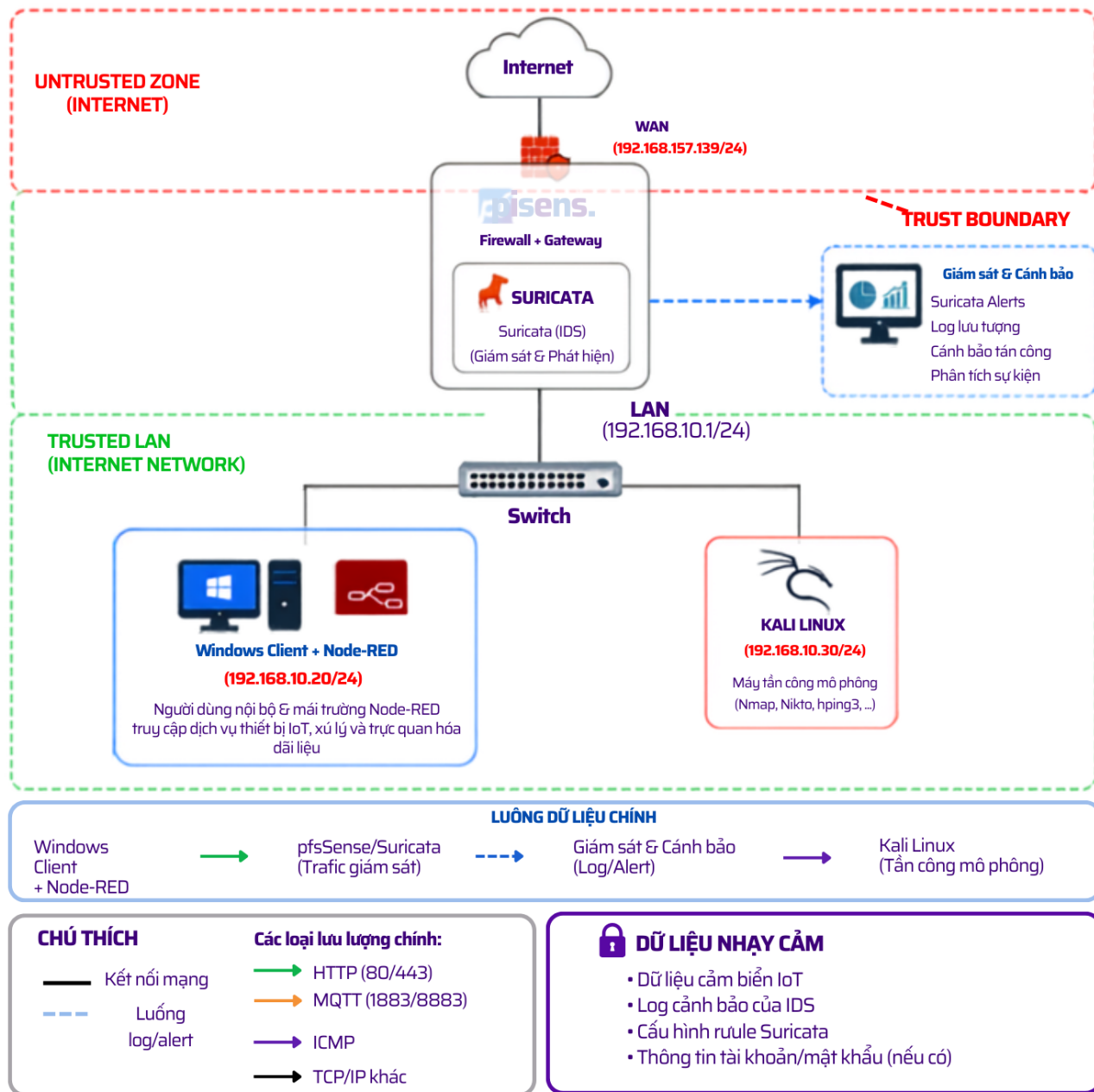
Mô hình mối đe dọa: phương pháp Threat Modeling được áp dụng trong đề tài này nhằm xác định các tài sản cần bảo vệ, các mối đe dọa phát sinh và những kiểu tấn công có khả năng xảy ra trong môi trường IoT. Dựa vào kiến trúc hệ thống, các tài sản quan trọng như thiết bị IoT, nhật ký cảnh báo của IDS, lưu lượng mạng và các tệp cấu hình. Từ đó xác định các nguy cơ tấn công quét cổng, tạo lưu lượng bất thường, dò tìm dịch vụ và truy cập trái phép để xây dựng các kịch bản kiểm thử phù hợp.

Phân tích rủi ro: đánh giá mức độ ảnh hưởng và khả năng xảy ra của từng rủi ro đối với hệ thống. Những rủi ro có mức ưu tiên cao, chẳng hạn như truy cập trái phép hoặc quét cổng nhằm thu thập thông tin dịch vụ, được lựa chọn để kiểm thử.

Kiểm thử bảo mật: dùng Kali Linux để tạo các kịch bản tấn công đến Windows Client thông qua pfSense. Suricata được sử dụng để phân tích lưu lượng trên các tập luật đã cấu hình và sinh cảnh báo khi phát hiện hành vi bất thường. Dựa trên nhật ký cảnh báo (Log) kết quả kiểm thử sẽ được đánh giá toàn diện, qua đó xác định khả năng phát hiện của hệ thống đối với từng kịch bản đã xây dựng.

3.2. Kiến trúc/mô hình và luồng dữ liệu

3.2.1. Kiến trúc hệ thống



Hình 3.1. Mô hình triển khai hệ thống phát hiện xâm nhập cho mạng IoT

Nguồn: Chatgpt.com

Trong mô hình, pfSense đóng vai trò là cổng kết nối giữa internet và mạng nội bộ. Thiết bị này chịu trách nhiệm định tuyến lưu lượng, chuyển tiếp dữ liệu giữa các vùng mạng và thực thi các chính sách tường lửa. Đồng thời, Suricata được cài đặt trực tiếp trên pfSense để giám sát toàn bộ lưu lượng đi qua gateway.

Mạng Lan được kết nối thông qua một switch và bao gồm 2 máy tính:

- Windows Client + Node-RED (192.168.10.20/24): thực hiện nhiệm vụ truy cập các dịch vụ IoT và tạo ra lưu lượng hoạt động bình thường của hệ thống.

- Kali Linux (192.168.10.30/24): đây là máy kiểm thử bảo mật, được sử dụng tạo các kịch bản tấn công như quét cổng, dò tìm dịch vụ hoặc sinh lưu lượng bất thường.

3.2.2. Phân vùng tin cậy của hệ thống

Untrusted Zone: vùng mạng này đại diện cho Internet hoặc các nguồn lưu lượng không đáng tin cậy. Kết nối từ vùng này điều phải đi qua pfSense trước khi truy cập vào hệ thống nội bộ.

Trust Boundary: đây là ranh giới giữa vùng tin cậy và mạng nội bộ được đặt tại vị trí của pfSense và Suricata IDS, tất cả gói tin đi qua khu vực này đều được suricata phân tích theo các tập luật đã cấu hình nhằm phát hiện dấu hiệu bất thường.

Trust LAN: là mạng nội bộ chứa các máy phục vụ cho quá trình mô phỏng và kiểm thử bao gồm Windows Client, Node-RED, và Kali Linux. Đây là vùng có mức độ tin cậy cao hơn Internet, nhưng vẫn chịu sự giám sát của hệ thống để phát hiện kịp thời các dấu hiệu của những hành vi bất thường.

IoT Zone: vùng này nhấn mạnh các đối tượng chính cần bảo vệ của đề tài là thiết bị và dịch vụ IoT. Trong mô hình, Node-RED đại diện cho thiết bị IoT thực hiện gửi và nhận dữ liệu qua HTTP hoặc MQTT.

3.2.3. Dữ liệu nhạy cảm trong hệ thống

Các dữ liệu nhạy cảm bao gồm: dữ liệu cảm biến hoặc dữ liệu IoT được Node-RED tạo ra và xử lý; Tập luật Rule của Suricata; Nhật ký cảnh báo của Suricata; Cấu hình pfSense; Thông tin xác thực của tài khoản quản trị.

3.3. Môi trường, công cụ và dữ liệu

Bảng 3.1. Thành phần, công cụ và dữ liệu

Thành phần	Phiên bản	Mục đích	Ghi chú an toàn
VMware Workstation	17.x	Tạo và quản lý các máy ảo trong môi trường thực nghiệm	Chỉ triển khai trong máy tính cá nhân, không kết nối trực tiếp với hệ thống thật
pfSense CE	2.7.x	Firewall, Gateway và quản lý lưu lượng mạng	Chỉ cho phép lưu lượng theo các rule đã cấu hình
Suricata IDS	7.x	Giám sát lưu lượng và phát hiện hành vi bất thường	Chỉ hoạt động ở chế độ IDS, không tự động chặn lưu lượng
Windows 10, Node-RED	22H2, 4.x	Máy người dùng hợp lệ truy cập dịch vụ IoT, Mô phỏng thiết bị và dịch vụ IoT	Không lưu trữ thông tin cá nhân, Sử dụng dữ liệu mô phỏng, không chứa dữ liệu thực
Kali Linux	2024.x	Tạo các kịch bản kiểm thử bảo mật	Chỉ kiểm thử trong môi trường phòng thí nghiệm, không thực hiện trên Internet

3.4. Quy trình thực hiện

Bảng 3.2. Quy trình thực hiện

Bước	Công việc	Đầu ra	Minh chứng trong repo
1	Xây dựng môi trường VMware	Các máy ảo được tạo	results/topology.png, configs/network.md
2	Cấu hình pfSense	Firewall hoạt động	results/pfsense-config.png, configs/pfsense.md
3	Cài Suricata	IDS hoạt động	results/suricata-dashboard.png, configs/suricata-rules.rules
4	Cài đặt Windows Client và Thiết lập Node-RED	Flow IoT	configs/node-red-flow.json, results/node-red.png
5	Kiểm thử bằng Kali	Alert Log	results/nmap-test.png
6	Đánh giá kết quả	Báo cáo	report/Report.pdf, results/analysis.md

3.5. Tiêu chí đánh giá

Bảng 3.3. Tiêu chí đánh giá

Tiêu chí	Ngưỡng đạt
Node-RED hoạt động ổn định	Truy cập thành công endpoint /sensor
Suricata giám sát lưu lượng	Có log khi phát sinh lưu lượng
Phát hiện Port Scan	Sinh cảnh báo khi Nmap quét
Ghi log đầy đủ	Log hiển thị IP nguồn, IP đích, thời gian và Rule
Kịch bản kiểm thử	Ít nhất 3/3 kịch bản đạt kết quả mong đợi

CHƯƠNG 4: TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường

Phần mềm mà đề tài sử dụng là: VMware Workstation; pfSense CE 2.6.0; Kaili Linux; Windows 10; Node-RED; Suricata IDS.

Bảng 4.1. Cấu hình mạng

Thiết bị	Địa chỉ IP	Vai trò
pfSense LAN	192.168.10.1/24	Gateway
Windows Client + Node-RED	192.168.10.20/24	Mô phỏng dịch vụ IoT
Kali Linux	192.168.10.30/24	Thiết bị kiểm thử

Trong mô hình thực nghiệm, máy Kali Linux được triển khai trong cùng mạng LAN với máy chủ Node-RED nhằm mô phỏng một thiết bị hoặc người dùng nội bộ thực hiện các thao tác truy cập và kiểm thử dịch vụ IoT. Việc bố trí này giúp tạo ra lưu lượng mạng thực tế để đánh giá khả năng giám sát và phát hiện của hệ thống IDS Suricata đối với các hoạt động diễn ra trong mạng nội bộ. Sau khi tạo lưu lượng HTTP thông thường đến dịch vụ Node-RED, máy Kali Linux tiếp tục thực hiện quét bằng công cụ Nmap để kiểm tra khả năng phát hiện các hành vi bất thường của Suricata.

4.2. Thành phần sản phẩm

Bảng 4.2. Thành phần sản phẩm

STT	Thành phần	Đường dẫn repo	Chức năng	Người thực hiện
1	README.md	https://github.com/quockiet031220-glitch/QuocKiet_BM	Giới thiệu đề tài, mô tả cấu trúc repository và hướng dẫn sử dụng.	Nguyễn Quốc Kiệt

STT	Thành phần	Đường dẫn repo	Chức năng	Người thực hiện
		IOT_Project/blob/main/README.md		
2	configs	https://github.com/quockiet031220-glitch/QuocKiet_BM_IOT_Project/tree/main/configs	Lưu cấu hình pfSense và danh sách luật Suricata được sử dụng trong hệ thống IDS.	Nguyễn Quốc Kiệt
3	data	https://github.com/quockiet031220-glitch/QuocKiet_BM_IOT_Project/tree/main/data	Lưu dữ liệu mẫu của cảm biến IoT phục vụ mô phỏng và kiểm thử.	Nguyễn Quốc Kiệt
4	images	https://github.com/quockiet031220-glitch/QuocKiet_BM_IOT_Project/tree/main/results	Lưu sơ đồ mạng, ảnh cấu hình và kết quả thực nghiệm được sử dụng trong báo cáo.	Nguyễn Quốc Kiệt
5	references	https://github.com/quockiet031220-glitch/QuocKiet_BM_IOT_Project/tree/main/references	Lưu tài liệu tham khảo của đề tài.	Nguyễn Quốc Kiệt
6	report	https://github.com/quockiet031220-glitch/QuocKiet_BM_IOT_Project/tree/main/report	Lưu báo cáo đồ án ở định dạng Word và PDF.	Nguyễn Quốc Kiệt

STT	Thành phần	Đường dẫn repo	Chức năng	Người thực hiện
7	src	https://github.com/quockiet031220-glitch/QuocKiet_BM_IOT_Project/tree/main/src	Lưu flow Node-RED và các tệp phục vụ triển khai hệ thống mô phỏng IoT.	Nguyễn Quốc Kiệt

4.3. Kịch bản thử nghiệm/đánh giá

Bảng 4.3. Kịch bản thử nghiệm/đánh giá

ID	Mục tiêu	Đầu vào	Thao tác	Kết quả mong đợi	Minh chứng
TC-01	Kiểm tra dịch vụ IoT hoạt động	Máy Windows 10 chạy Node-RED	Truy cập <code>http://127.0.0.1:1880/sensor</code> trên trình duyệt	API hoạt động và trả về dữ liệu JSON của cảm biến	Hình 5.24
TC-02	Kiểm tra khả năng truy cập dịch vụ IoT từ thiết bị trong mạng LAN	Máy Kali Linux (192.168.1.0.30)	Thực hiện lệnh <code>curl http://192.168.1.0.20:1880/sensor</code>	Kali Linux nhận được dữ liệu JSON từ Node-RED	Hình 5.25
TC-03	Tạo lưu lượng HTTP phục vụ giám sát	Máy Kali Linux	Chạy lệnh <code>curl</code> gửi yêu cầu HTTP liên tục đến Node-RED	Hệ thống tạo lưu lượng HTTP bình thường trong mạng LAN	Hình 5.26
TC-04	Mô phỏng hành vi quét mạng	Máy Kali Linux	Thực hiện lệnh <code>sudo nmap -A 192.168.10.20</code>	Quét mạng được thực hiện thành công	Hình 5.27
TC-05	Đánh giá khả năng phát hiện xâm nhập của Suricata	Suricata IDS trên pfSense	Kiểm tra mục Alerts sau khi quét Nmap	Suricata sinh cảnh báo "ET SCAN Possible Nmap User-Agent Observed"	Hình 5.29

4.4. Kết quả

The image displays three stacked screenshots from VMware Workstation, illustrating a network setup across different virtual machines.

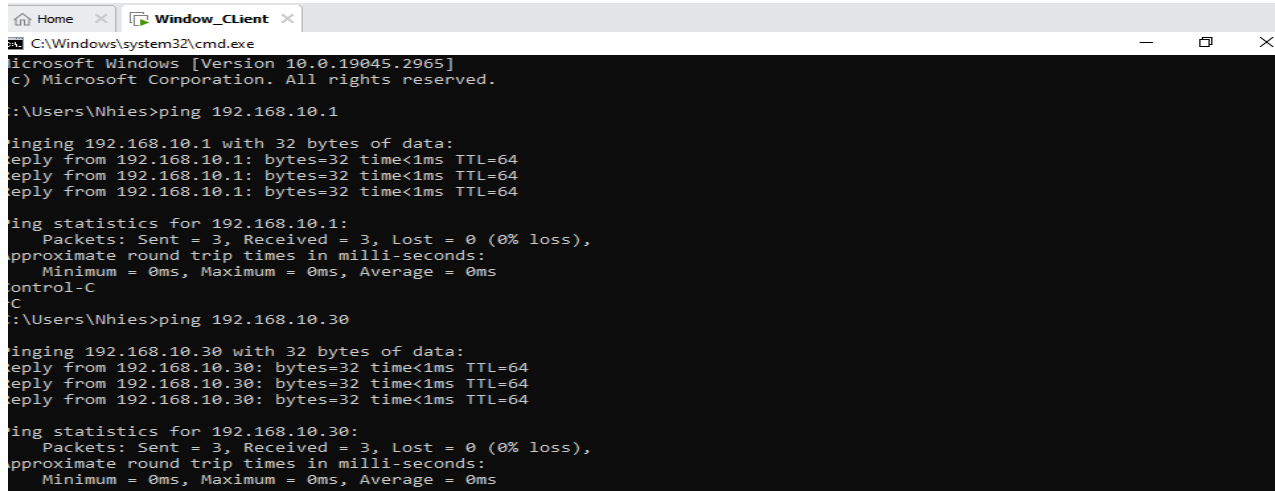
Top Window: HQ_Kali - VMware Workstation
The terminal shows the output of the `ip a` command in a Kali Linux VM. It details the configuration for the loopback interface `lo` and the Ethernet interface `eth0`, including their MTUs, flags, and assigned IP addresses (192.168.10.1 for `lo` and 192.168.10.20 for `eth0`).

Middle Window: Window_Client - VMware Workstation
The terminal shows the output of the `ipconfig` command in a Windows VM. It displays the IP configuration for the Ethernet adapter 'Ethernet0', showing an IPv4 address of 192.168.10.20 and a subnet mask of 255.255.255.0.

Bottom Window: pfSense - VMware Workstation
The terminal shows the boot sequence of a pfSense VM. It includes messages about starting syslog and CRON, the pfSense version (2.6.8-RELEASE amd64), and the completion of the boot process. It also displays the IP configuration for the LAN interface, showing an IPv4 address of 192.168.10.1/24.

Hình 4.1. Môi trường thực nghiệm hệ thống trên VMware Workstation

Kiểm tra xem các máy có thể giao tiếp với nhau được không bằng lệnh ping lần lượt trên từng máy



```
C:\Windows\system32\cmd.exe
Microsoft Windows [Version 10.0.19045.2965]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Nhies>ping 192.168.10.1

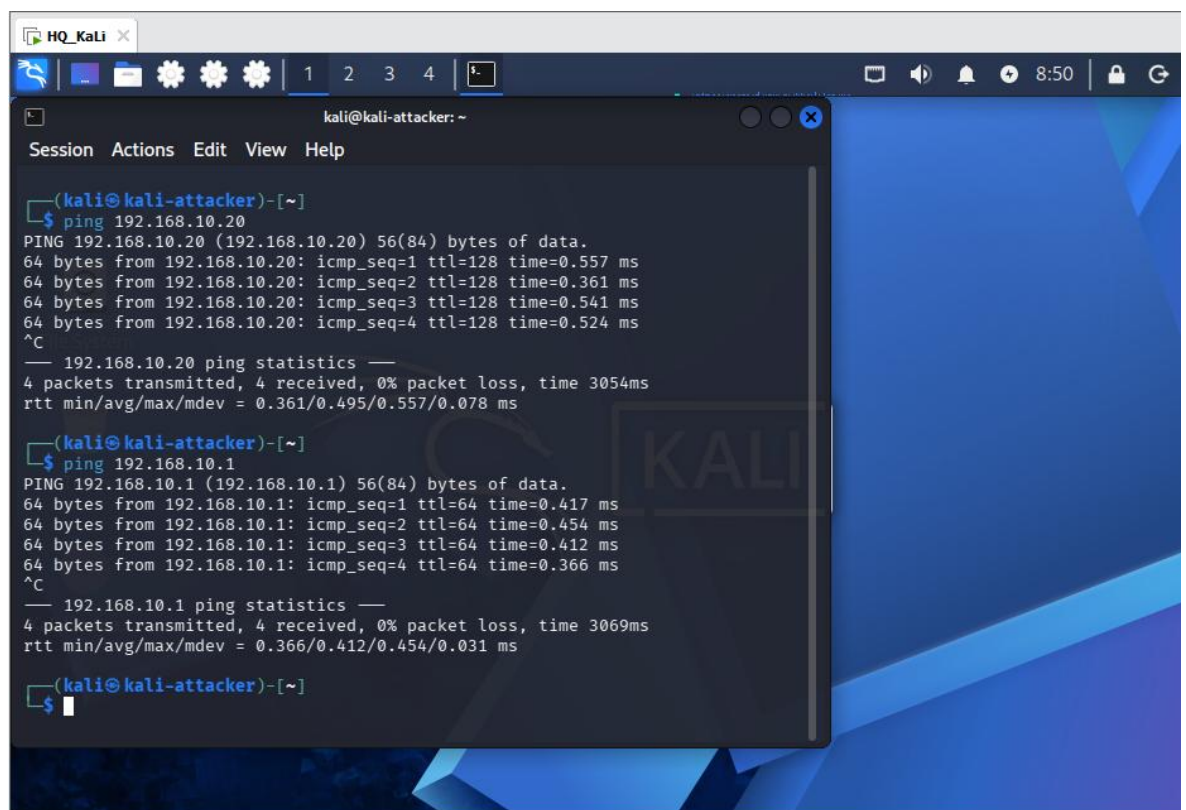
Pinging 192.168.10.1 with 32 bytes of data:
Reply from 192.168.10.1: bytes=32 time<1ms TTL=64
Reply from 192.168.10.1: bytes=32 time<1ms TTL=64
Reply from 192.168.10.1: bytes=32 time<1ms TTL=64

Ping statistics for 192.168.10.1:
    Packets: Sent = 3, Received = 3, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
C:\Users\Nhies>ping 192.168.10.30

Pinging 192.168.10.30 with 32 bytes of data:
Reply from 192.168.10.30: bytes=32 time<1ms TTL=64
Reply from 192.168.10.30: bytes=32 time<1ms TTL=64
Reply from 192.168.10.30: bytes=32 time<1ms TTL=64

Ping statistics for 192.168.10.30:
    Packets: Sent = 3, Received = 3, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms
```

Hình 4.2. Windows Client kiểm tra kết nối đến pfSense và Kali Linux



```
kali@kali-attacker: ~
Session Actions Edit View Help

(kali@kali-attacker)-[~]
$ ping 192.168.10.20
PING 192.168.10.20 (192.168.10.20) 56(84) bytes of data:
64 bytes from 192.168.10.20: icmp_seq=1 ttl=128 time=0.557 ms
64 bytes from 192.168.10.20: icmp_seq=2 ttl=128 time=0.361 ms
64 bytes from 192.168.10.20: icmp_seq=3 ttl=128 time=0.541 ms
64 bytes from 192.168.10.20: icmp_seq=4 ttl=128 time=0.524 ms
^C
--- 192.168.10.20 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3054ms
rtt min/avg/max/mdev = 0.361/0.495/0.557/0.078 ms

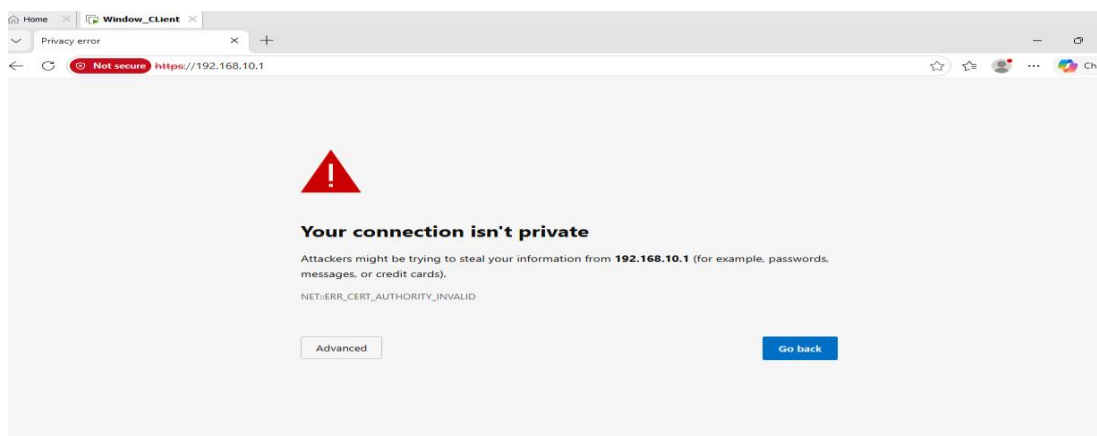
(kali@kali-attacker)-[~]
$ ping 192.168.10.1
PING 192.168.10.1 (192.168.10.1) 56(84) bytes of data:
64 bytes from 192.168.10.1: icmp_seq=1 ttl=64 time=0.417 ms
64 bytes from 192.168.10.1: icmp_seq=2 ttl=64 time=0.454 ms
64 bytes from 192.168.10.1: icmp_seq=3 ttl=64 time=0.412 ms
64 bytes from 192.168.10.1: icmp_seq=4 ttl=64 time=0.366 ms
^C
--- 192.168.10.1 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3069ms
rtt min/avg/max/mdev = 0.366/0.412/0.454/0.031 ms

(kali@kali-attacker)-[~]
$
```

Hình 4.3. Kali Linux kiểm tra kết nối đến pfSense và Windows Client

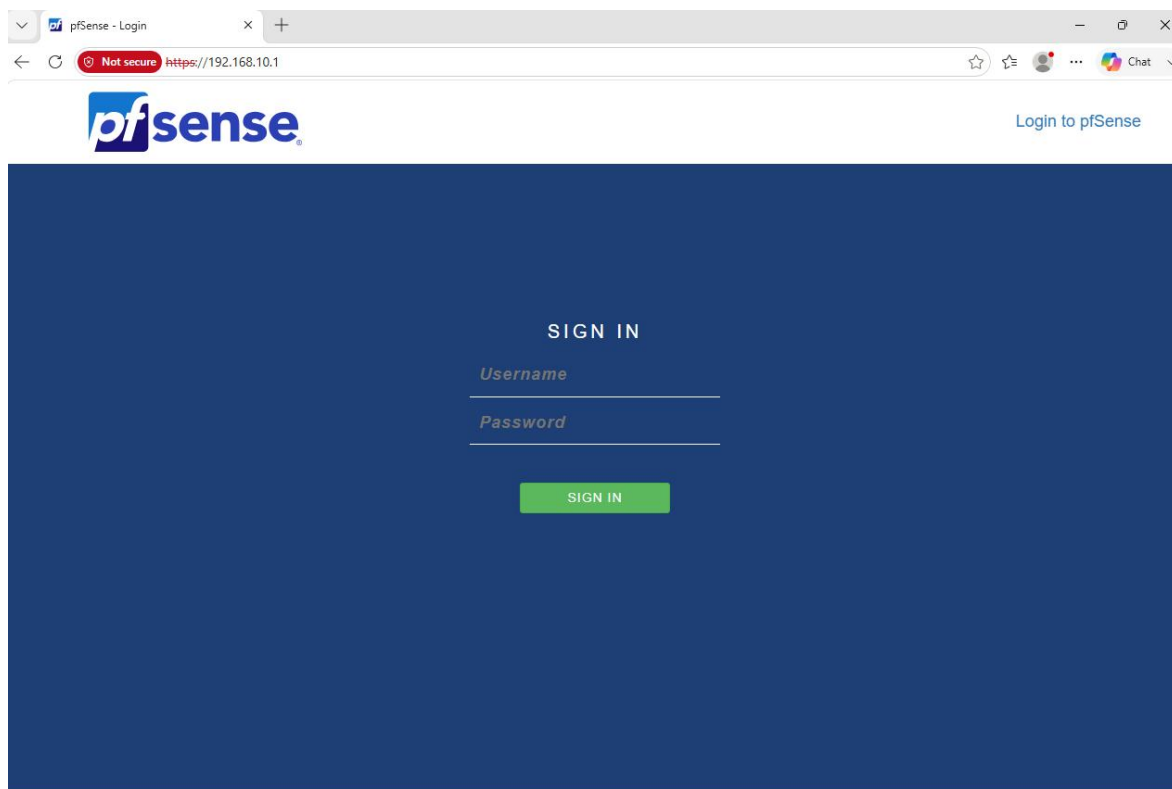
Dựa vào các gói tin đều được phản hồi thành công với tỷ lệ mất gói bằng 0%, chứng tỏ các thiết bị đã kết nối đúng trong mạng LAN và sẵn sàng cho các bước thực nghiệm tiếp theo.

Tiến hành đăng nhập WebConfigurator trên máy client bằng địa chỉ IP 192.168.10.1



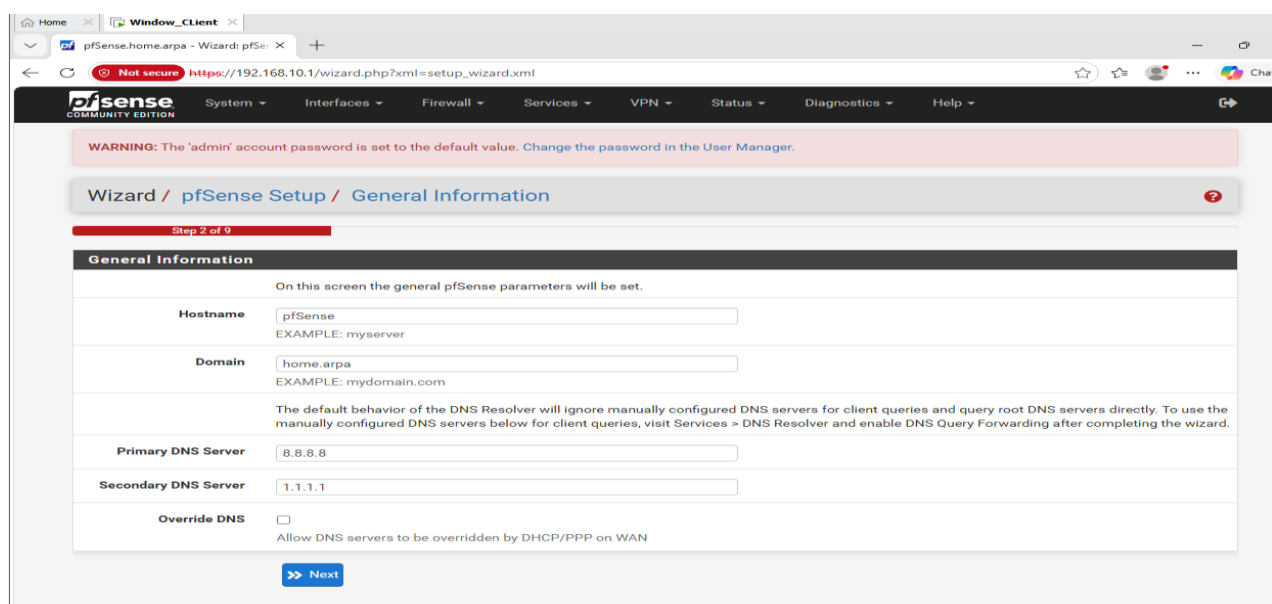
Hình 4.4. Đăng nhập WebConfigurator của pfSense

Chọn Advanced -> Continue to 192.168.10.1, sau đó sẽ hiển thị giao diện WebConfigurator

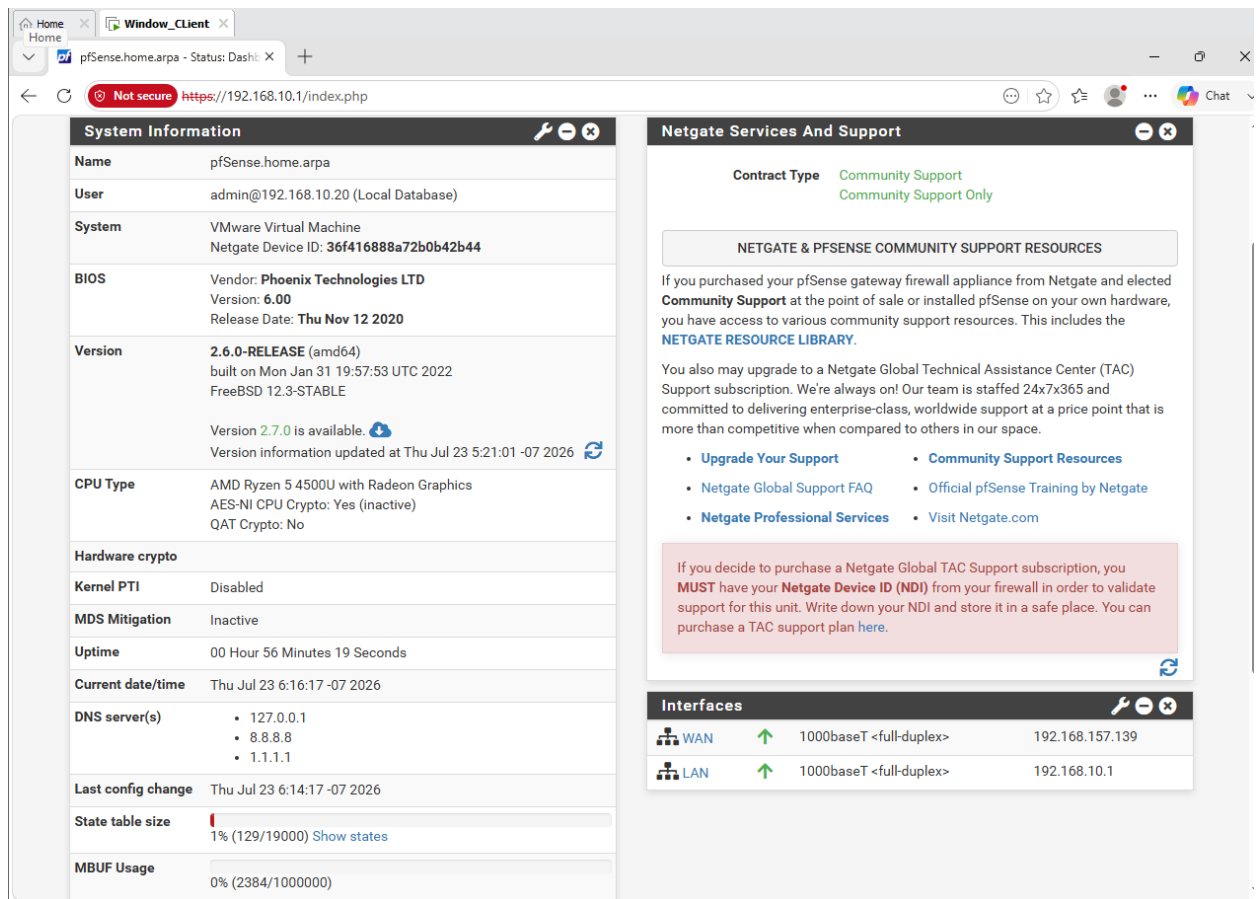


Hình 4.5. Giao diện WebConfigurator pfSense

Sau đó đăng nhập bằng tài khoản và mật khẩu admin trang web sẽ chuyển đến giao diện thiết lập ban đầu của pfSense

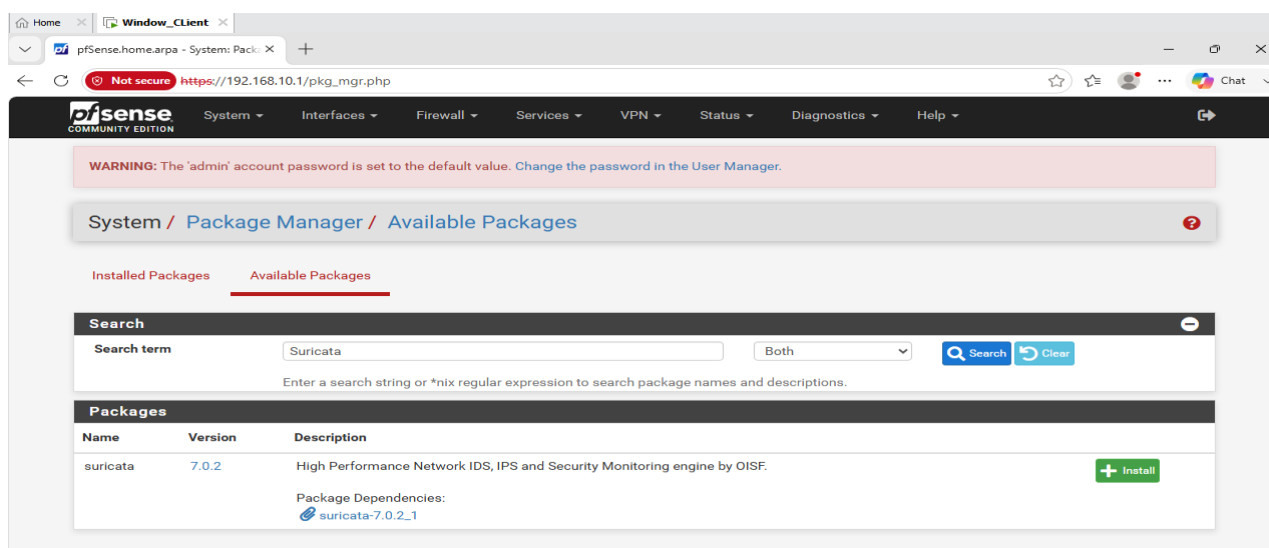


Hình 4.6. Trình hướng dẫn thiết lập ban đầu của pfSense

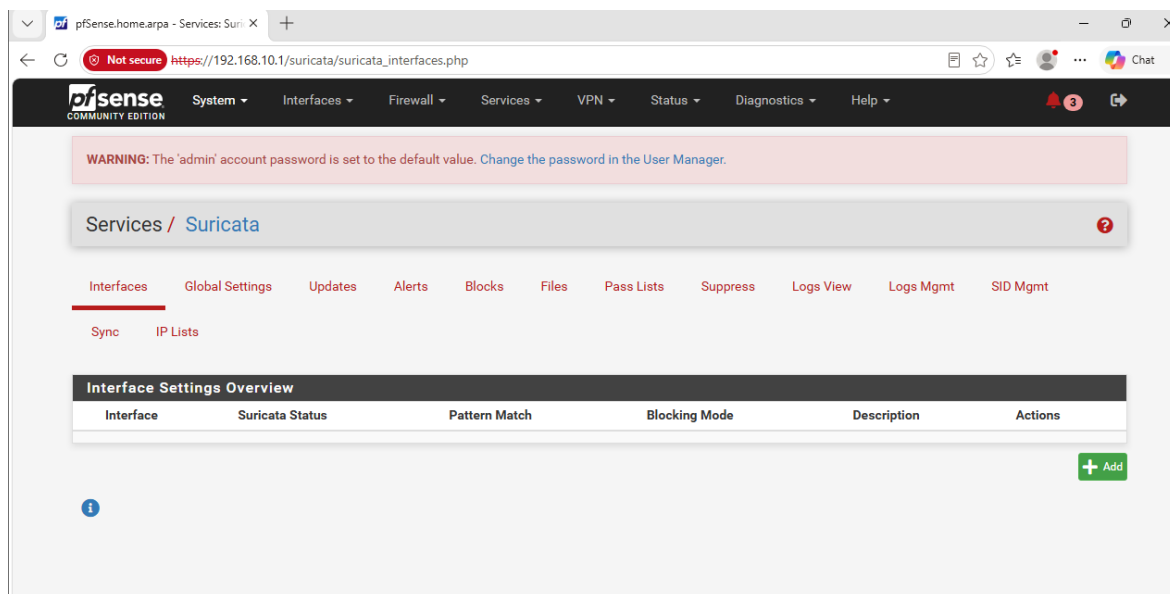


Hình 4.7. Giao diện quản trị chính của pfSense

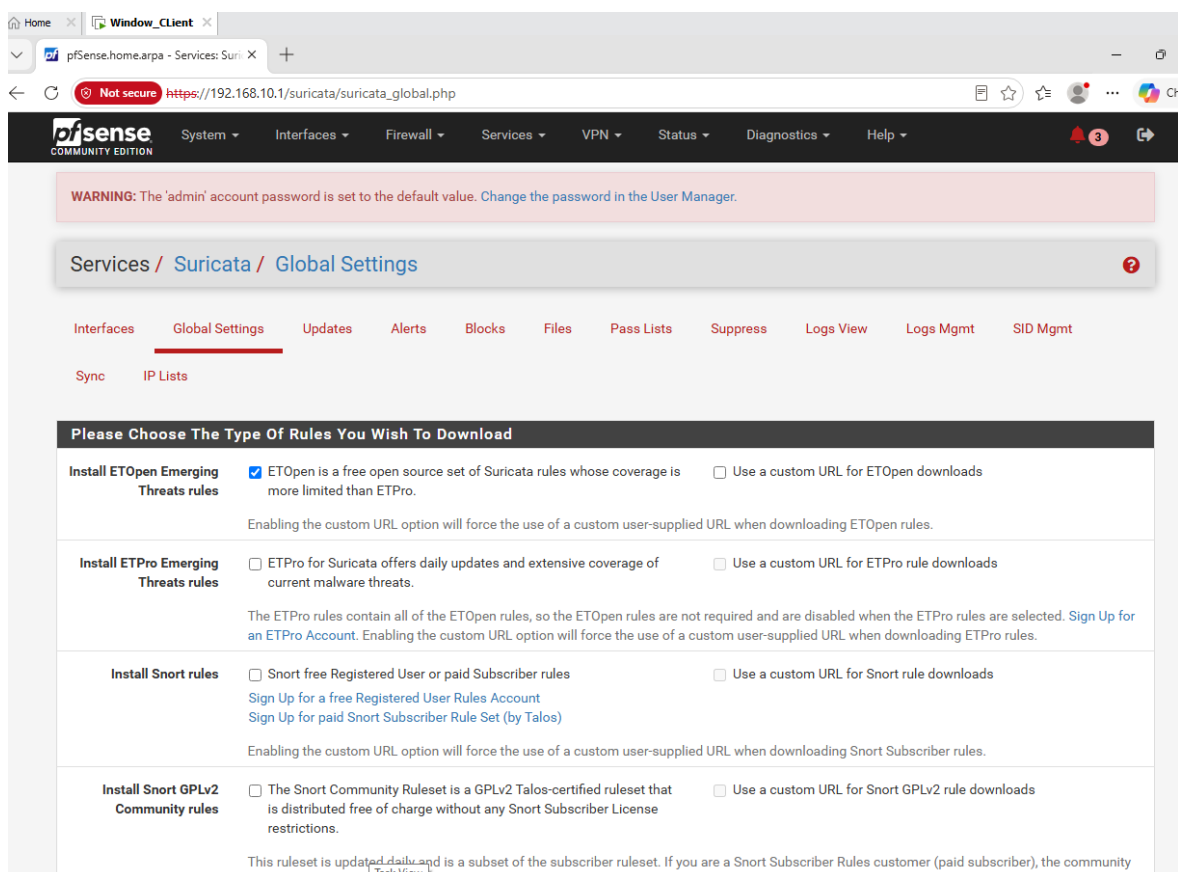
Tiến hành vào mục System -> Package Manager -> Available Packages để tìm kiếm và cài đặt Suricata



Hình 4.8. Cài đặt gói Suricata IDS trên pfSense



Hình 4.9. Giao diện của Suricata sau khi cài đặt thành công



Hình 4.10. Cấu hình bộ luật và cơ chế cập nhật của Suricata IDS

Rules Update Settings

Update Interval

12 HOURS

Please select the interval for rule updates. Choosing NEVER disables auto-updates.

Hint: In most cases, every 12 hours is a good choice.

Update Start Time

00:47

Enter the rule update start time in 24-hour format (HH:MM). Default is 00 hours with a randomly chosen minutes value. Rules will update at the interval chosen above starting at the time specified here. For example, using a start time of 00:08 and choosing 12 Hours for the interval, the rules will update at 00:08 and 12:08 each day. The randomized minutes value should be retained to minimize the impact to the rules update site from large numbers of simultaneous requests.

Live Rule Swap on Update

☐ Enable "Live Swap" reload of rules after downloading an update. Default is Not Checked

When enabled, Suricata will perform a live load of the new rules following an update instead of a hard restart. If issues are encountered with live load, uncheck this option to perform a hard restart of all Suricata instances following an update.

GeoLite2 DB Update

☐ Enable downloading of free GeoLite2 Country IP Database updates. Default is Not Checked

When enabled, Suricata will automatically download updates for the free GeoLite2 country IP database.

If you have a subscription for more current GeoIP2 updates, uncheck this option and instead create your own process to place the required database file in `/usr/local/share/suricata/GeoLite2/`.

Hệ thống được cấu hình sử dụng bộ luật Emerging Threats Open (ETOpen) và thiết lập cơ chế cập nhật định kỳ nhằm đảm bảo cơ sở dữ liệu nhận diện các mối đe dọa luôn được cập nhật.

Tiếp tục vào Interface tích vào mục Add để tạo interface giám sát

Services / Suricata / WAN - Interface Settings

WARNING! Suricata now requires that Hardware Checksum Offloading, Hardware TCP Segmentation Offloading and Hardware Large Receive Offloading all be disabled for proper operation. This firewall currently has one or more of these Offloading settings NOT disabled. Visit the [System > Advanced > Networking](#) tab and ensure all three of these Offloading settings are disabled.

Interfaces Global Settings Updates Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

WAN Settings

General Settings

Enable ☒ Checking this box enables Suricata inspection on the interface.

Interface LAN (em1)
Choose which interface this Suricata instance applies to. In most cases, you will want to choose LAN here if this is the first Suricata-configured interface.

Description LAN_IDS
Enter a meaningful description here for your reference. The default is the pfSense interface friendly description.

Logging Settings

Hình 4.13. Thiết lập giao diện LAN cho Suricata

Services / Suricata

Interfaces Global Settings Updates Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

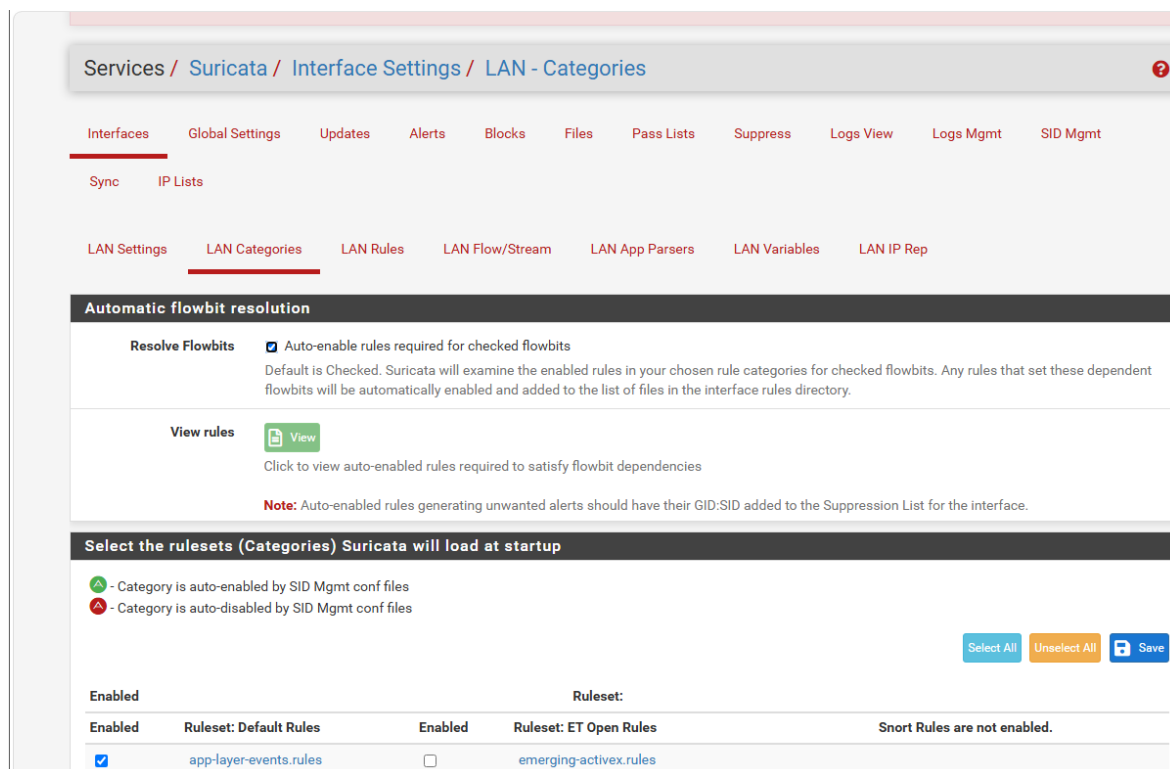
Interface Settings Overview

Interface	Suricata Status	Pattern Match	Blocking Mode	Description	Actions
☐ LAN (em1)	❌ ▶	AUTO	DISABLED	LAN_IDS	✎ 📄 🗑

[+ Add](#) [Delete](#)

Hình 4.14. Giao diện Interface Lan sau khi được thiết lập

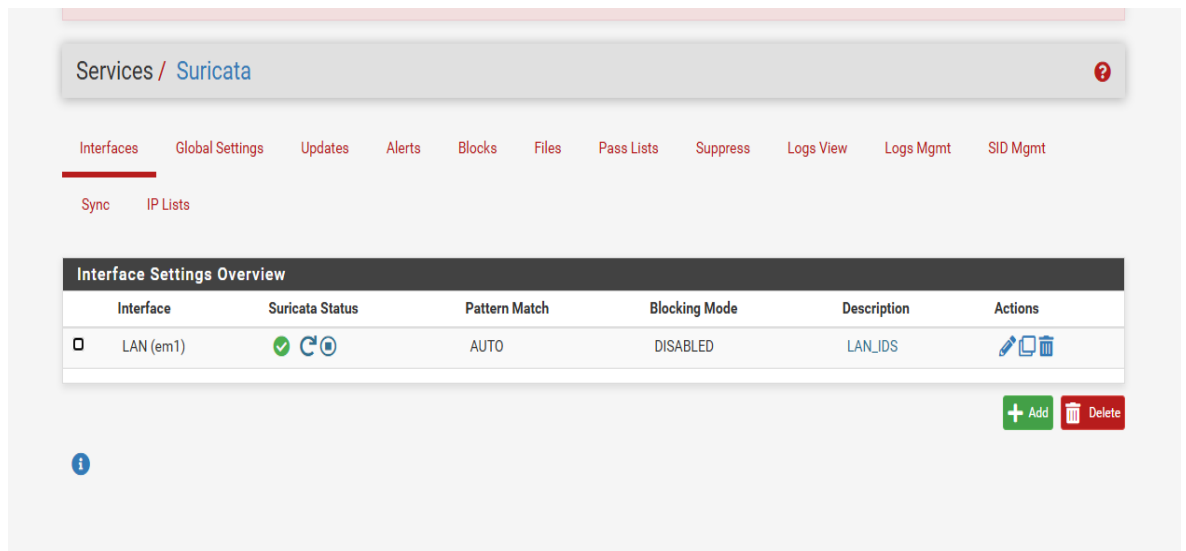
Vào LAN Categories để lựa chọn nhóm luật cần kích hoạt để Suricata giám sát và phát hiện các hành vi bất thường trên giao diện mạng LAN



Hình 4.15. Giao diện lựa chọn nhóm luật phát hiện xâm nhập cho Suricata

☒	emerging-exploit.rules	☒	emerging-scan.rules
☐	emerging-exploit_kit.rules	☐	emerging-shellcode.rules
☐	emerging-file_sharing.rules	☐	emerging-smtp.rules
☐	emerging-ftp.rules	☐	emerging-snmp.rules
☐	emerging-games.rules	☐	emerging-sql.rules
☐	emerging-hunting.rules	☐	emerging-ta_abused_services.rules
☒	emerging-icmp.rules	☐	emerging-telnet.rules
☐	emerging-imap.rules	☐	emerging-tftp.rules
☐	emerging-inappropriate.rules	☐	emerging-threatview_CS_c2.rules
☐	emerging-info.rules	☐	emerging-tor.rules
☐	emerging-ja3.rules	☐	emerging-user_agents.rules
☒	emerging-malware.rules	☐	emerging-voip.rules
		☒	emerging-web_client.rules
		☒	emerging-web_server.rules

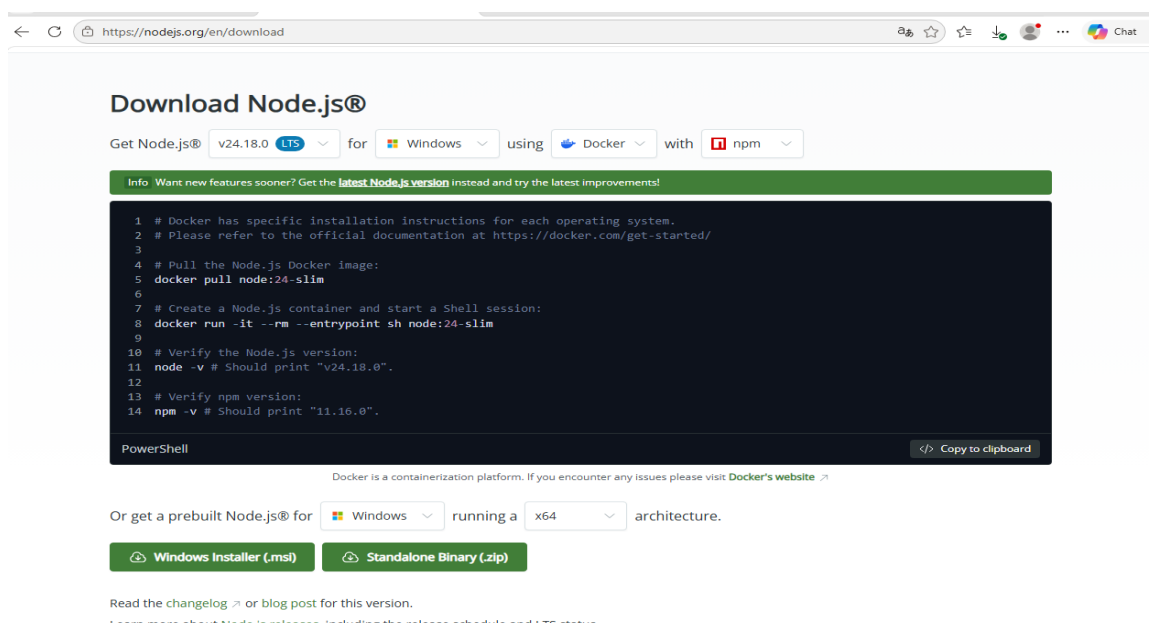
Hình 4.16. Lựa chọn các nhóm luật phát hiện xâm nhập của Suricata



Hình 4.17. Khởi động Suricata trên giao diện LAN

Sau khi lựa chọn các nhóm luật và hoàn tất cấu hình, Suricata được khởi động trên giao diện LAN để giám sát lưu lượng mạng. Khi trạng thái hiển thị Running, hệ thống IDS đã sẵn sàng phân tích các gói tin và phát hiện các hành vi bất thường theo các bộ luật đã cấu hình.

Tiếp theo tiến hành truy cập trang web <https://nodejs.org/> để tải Node.js



Hình 4.18. Giao diện trang web Node.js

```
C:\Windows\system32\cmd.exe
Microsoft Windows [Version 10.0.19045.6456]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Nhies>node -v
v24.18.0

C:\Users\Nhies>npm -v
11.16.0

C:\Users\Nhies>
```

Hình 4.19. Kiểm tra môi trường Node.js trên Windows Client

```
C:\Users\Nhies>npm install -g --unsafe-perm node-red
npm warn "node-red" is being parsed as a normal command line argument.
npm warn Unknown cli config "--unsafe-perm". This will stop working in the next major version of npm.

added 276 packages in 1m

70 packages are looking for funding
  run `npm fund` for details
```

Hình 4.20. Cài đặt Node-RED bằng npm

```
C:\Users\Nhies>node-red
23 Jul 22:13:26 - [info]
Welcome to Node-RED
=====
23 Jul 22:13:26 - [info] Node-RED version: v5.0.1
23 Jul 22:13:26 - [info] Node.js version: v24.18.0
23 Jul 22:13:26 - [info] Windows_NT 10.0.19045 x64 LE
23 Jul 22:13:26 - [info] Loading palette nodes
23 Jul 22:13:31 - [info] Settings file   : C:\Users\Nhies\.node-red\settings.js
23 Jul 22:13:31 - [info] Context store  : 'default' [module=memory]
23 Jul 22:13:31 - [info] User directory : C:\Users\Nhies\.node-red
23 Jul 22:13:31 - [warn] Projects disabled : editorTheme.projects.enabled=false
23 Jul 22:13:31 - [info] Flows file     : C:\Users\Nhies\.node-red\flows.json
23 Jul 22:13:31 - [info] Creating new flow file
23 Jul 22:13:31 - [warn]

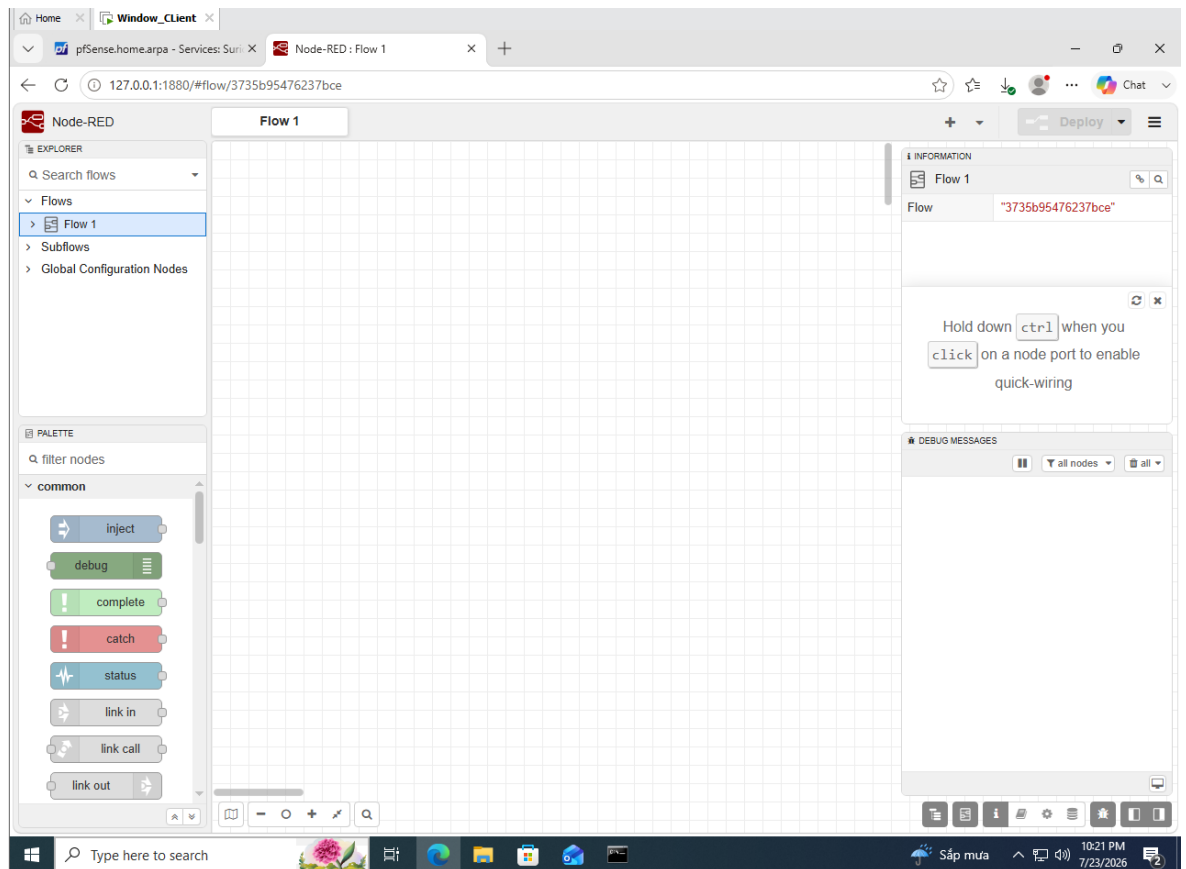
-----
Your flow credentials file is encrypted using a system-generated key.

If the system-generated key is lost for any reason, your credentials
file will not be recoverable, you will have to delete it and re-enter
your credentials.

You should set your own key using the 'credentialSecret' option in
your settings file. Node-RED will then re-encrypt your credentials
file using your chosen key the next time you deploy a change.
-----
23 Jul 22:13:31 - [info] Server now running at http://127.0.0.1:1880/
23 Jul 22:13:31 - [warn] Encrypted credentials not found
23 Jul 22:13:31 - [info] Starting flows
23 Jul 22:13:31 - [info] Started flows
```

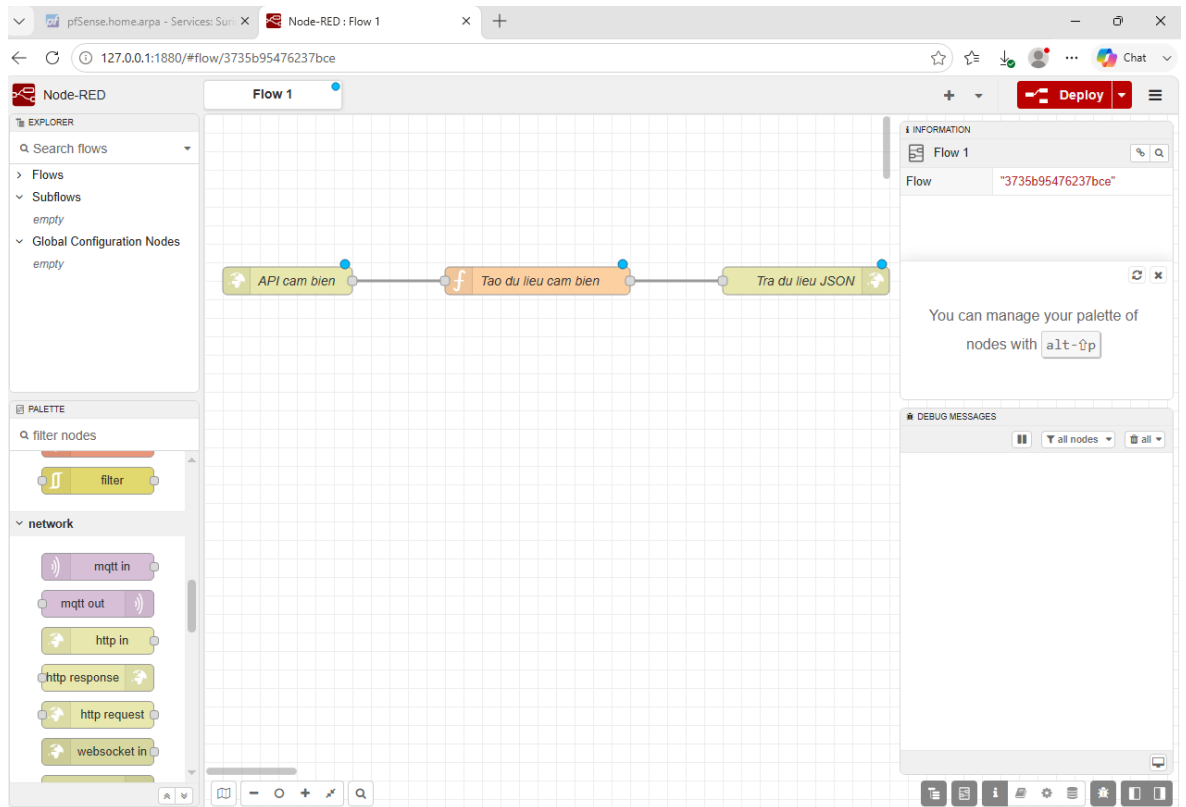
Hình 4.21. Khởi động dịch vụ Node-RED trên Windows Client

Khi khởi động dịch vụ Node-RED thành công tiến hành dùng địa chỉ <http://127.0.0.1:1880> để truy cập giao diện quản lý Node-RED



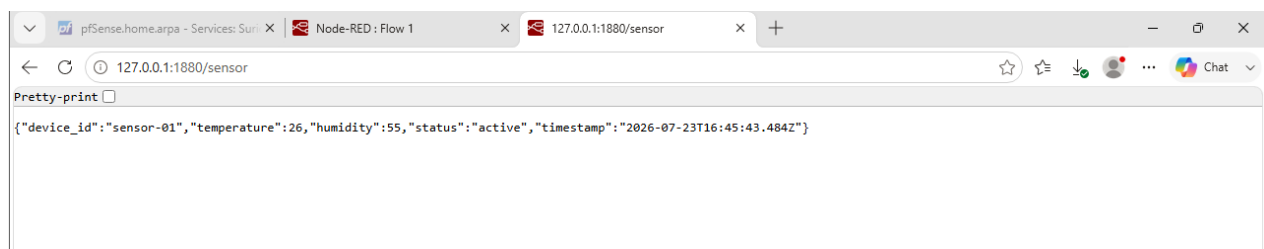
Hình 4.22. Giao diện quản lý Node-RED trên Windows Client

Giao diện này cho phép xây dựng và quản lý các luồng dữ liệu phục vụ mô phỏng hoạt động của thiết bị IoT.

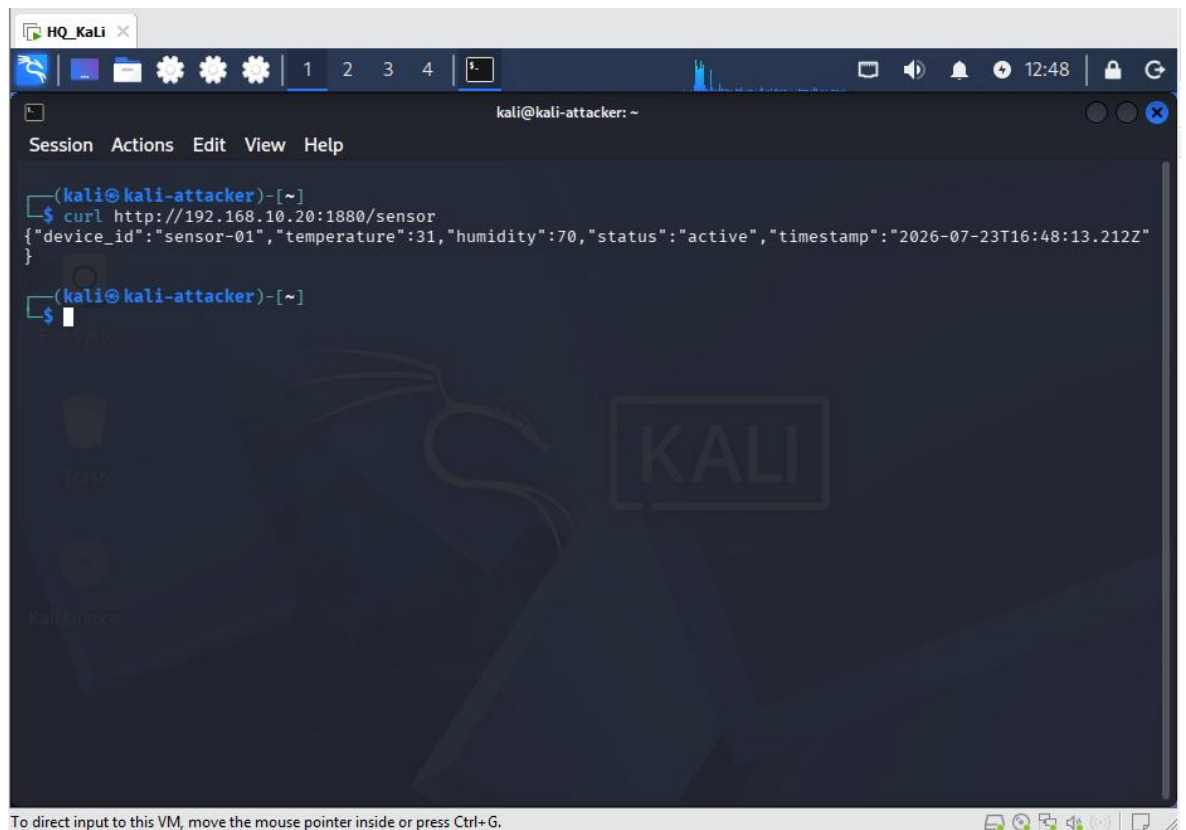


Hình 4.23. Cấu hình luồng mô phỏng dịch vụ cảm biến IoT trên Node-RED

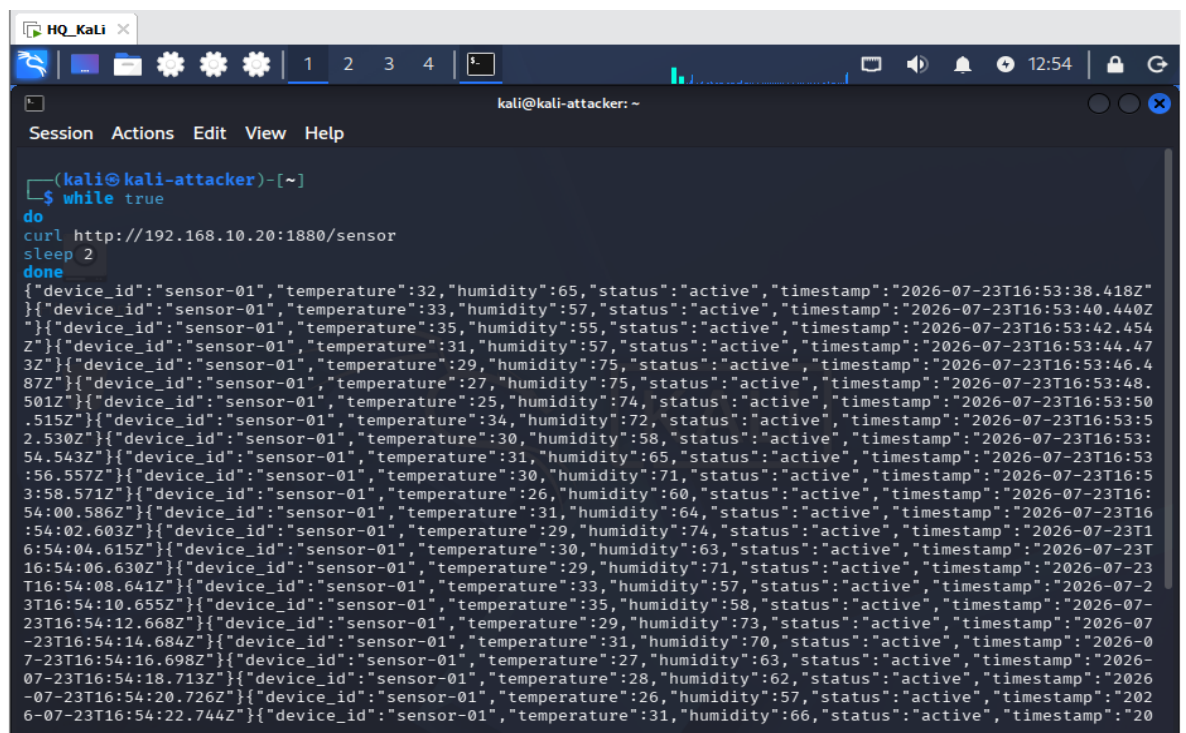
Node-RED được cấu hình thành ba thành phần: API cảm biến để tiếp nhận yêu cầu HTTP, Tạo dữ liệu cảm biến để sinh dữ liệu mô phỏng dưới dạng JSON và Trả dữ liệu JSON để gửi kết quả về cho máy khách



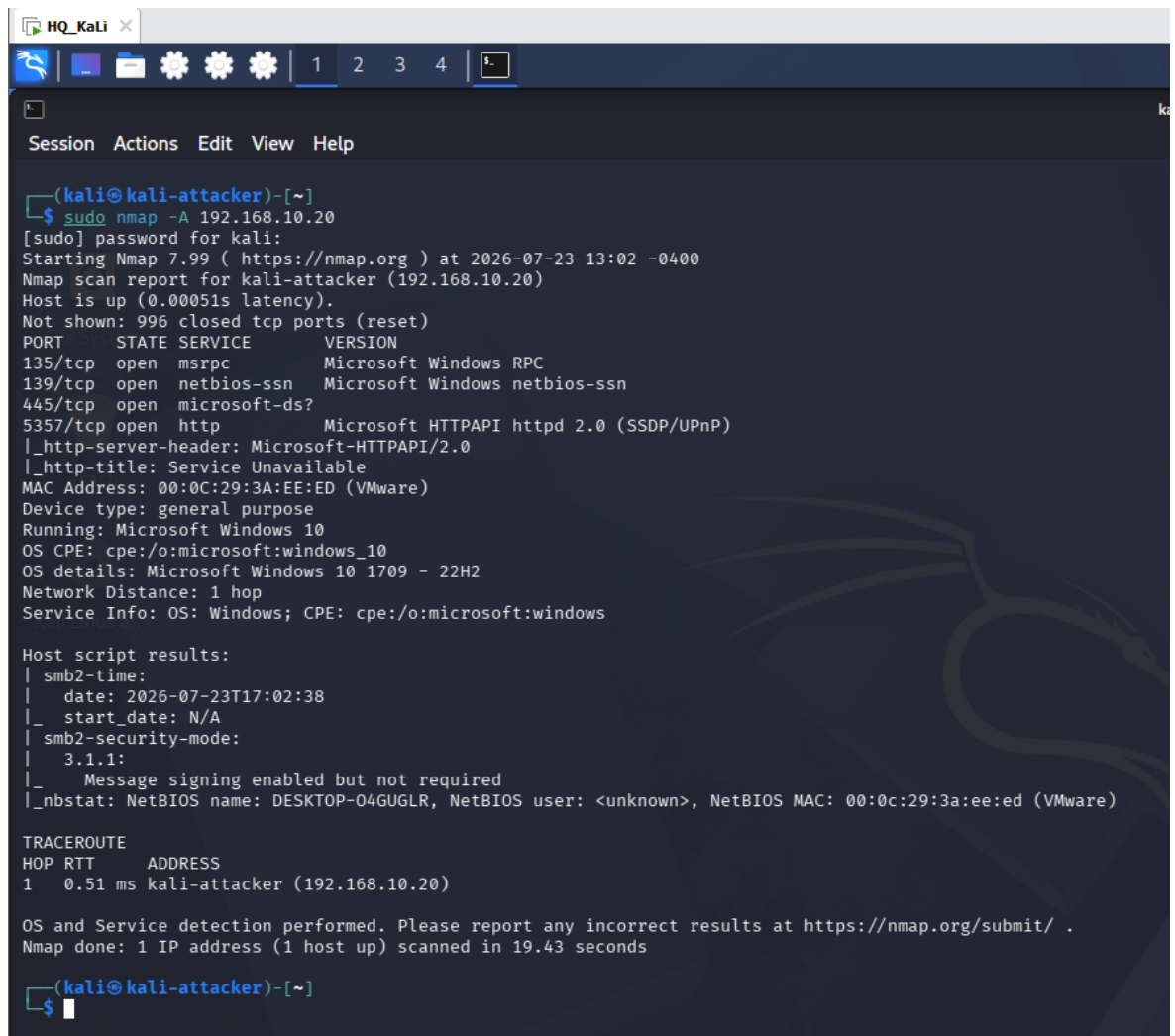
Hình 4.24. Kiểm tra hoạt động của dịch vụ cảm biến IoT trên Node-RED



Hình 4.25. Kết quả truy cập dịch vụ cảm biến IoT từ máy Kali Linux



Hình 4.26. Tạo lưu lượng HTTP từ máy Kali Linux đến dịch vụ Node-RED



```
(kali@kali-attacker)-[~]
$ sudo nmap -A 192.168.10.20
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-23 13:02 -0400
Nmap scan report for kali-attacker (192.168.10.20)
Host is up (0.00051s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc           Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
5357/tcp   open  http            Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Service Unavailable
MAC Address: 00:0C:29:3A:EE:ED (VMware)
Device type: general purpose
Running: Microsoft Windows 10
OS CPE: cpe:/o:microsoft:windows_10
OS details: Microsoft Windows 10 1709 - 22H2
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|   date: 2026-07-23T17:02:38
|_  start_date: N/A
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
|_ nbstat: NetBIOS name: DESKTOP-04GUGLR, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:3a:ee:ed (VMware)

TRACEROUTE
HOP RTT      ADDRESS
1   0.51 ms  kali-attacker (192.168.10.20)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.43 seconds

(kali@kali-attacker)-[~]
$
```

Hình 4.27. Kết quả quét cổng dịch vụ Node-RED bằng Nmap

Công cụ Nmap đã thu thập thông tin thành công về trạng thái hoạt động của các cổng dịch vụ và hệ điều hành của máy Windows Client, tạo lưu lượng phục vụ quá trình giám sát của Suricata.

Tiến hành quay lại máy Client mở web quản trị của pfSense chọn Services -> Suricata -> Alerts để xem cảnh báo

Services / Suricata / Alerts

Interfaces
Global Settings
Updates
Alerts
Blocks
Files
Pass Lists
Suppress
Logs View
Logs Mgmt
SID Mgmt

Sync
IP Lists

Alert Log View Settings

Instance to View
(LAN) LAN_IDS
Choose which instance alerts you want to inspect.

Save or Remove Logs

Download

Clear

All alert log files for selected interface will be downloaded
Clear the currently active Alerts log file

Save Settings

Save

Refresh

Default is ON

250

Number of alerts to display. Default is 250

Alert Log View Filter

Last 250 Alert Entries. (Most recent entries are listed first)

Hình 4.28. Giao diện trang cảnh báo

07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43952	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43816	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43822	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43826	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43840	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43846	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43856	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43866	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43870	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43884	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43894	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43896	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43912	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed
07/23/2026 10:02:38	1	TCP	Web Application Attack	192.168.10.30	43922	192.168.10.20	5357	1:2024364	ET SCAN Possible Nmap User-Agent Observed

Hình 4.29. Suricata IDS phát hiện hoạt động quét cổng từ máy Kali Linux

Kết quả của log cho thấy Suricata đã phát hiện máy kali thực hiện hình thức quét cổng trên máy client và phát ra cảnh báo đến hệ thống.

Bảng kết quả theo từng kịch bản:

Bảng 4.4. Bảng tổng hợp

Kịch bản	Kết quả thực tế	Đánh giá
TC-01	Node-RED phản hồi dữ liệu	Đạt
TC-02	Suricata ghi nhận lưu lượng	Đạt
TC-03	Suricata phát hiện Port Scan	Đạt

4.5. Thảo luận & hạn chế

4.5.1. Thảo luận kết quả

Qua kết quả thực nghiệm cho thấy hệ thống đáp ứng các mục tiêu đặt ra ở Chương 1. Suricata IDS giám sát lưu lượng mạng, ghi nhận đầy đủ các sự kiện và phát hiện thành công hành vi quét cổng từ máy Kali Linux. Node-RED hoạt động ổn định trong vai trò mô phỏng thiết bị IoT và cung cấp dữ liệu qua giao thức HTTP. Các tiêu chí đánh giá đã xây dựng ở mục 3.5, cho thấy mô hình có thể hỗ trợ giám sát và phát hiện các hoạt động bất thường trong môi trường mạng IoT mô phỏng.

4.5.2. Hạn chế

Do giới hạn về điều kiện thực hiện và thời gian, nên hệ thống chỉ được triển khai với số lượng thiết bị IoT bị hạn chế. Đề tài chưa đánh giá trên các thiết bị IoT thực tế và chưa kiểm thử nhiều loại hình tấn công khác ngoài các kịch bản đã xây dựng. Vì thế, kết quả chủ yếu phản ánh tính khả thi của giải pháp trong môi trường thử nghiệm và có thể được mở rộng trong tương lai.

CHƯƠNG 5: ĐÁNH GIÁ BẢO MẬT

5.1. Tài sản và dữ liệu cần bảo vệ

Bảng 5.1. Tài sản và dữ liệu cần bảo vệ

Tài sản/Dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Dịch vụ IoT Node-RED	Hệ thống IoT	Cao	C: Thấp I: Cao A: Cao	Cung cấp dữ liệu cảm biến
Dữ liệu cảm biến JSON	Node-RED	Trung bình	C: Thấp I: Cao A: Trung bình	Dữ liệu mô phỏng phục vụ kiểm thử
Cấu hình pfSense	Quản trị viên	Cao	C: Cao I: Cao A: Cao	Quyết định chính sách mạng và Firewall
Bộ luật Suricata (Rules)	Suricata IDS	Cao	C: Trung bình I: Cao A: Cao	Phục vụ phát hiện xâm nhập
Nhật ký cảnh báo (Alert Log)	Suricata IDS	Cao	C: Trung bình I: Cao A: Cao	Dùng để theo dõi và phân tích sự kiện
Máy Windows và Kali Linux	Người quản trị	Trung bình	C: Trung bình I: Trung bình A: Cao	Phục vụ mô phỏng và kiểm thử

5.2. Môi đe dọa và lỗ hổng

Bảng 5.2. Môi đe dọa và lỗ hổng

ID	Tài sản	Mối đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
T-01	Dịch vụ Node-RED	Quét cổng (Port Scanning)	Dịch vụ HTTP mở trên cổng 1880 có thể bị dò tìm	Kẻ tấn công có thể thu thập thông tin dịch vụ để chuẩn bị cho các bước tấn	Kịch bản kiểm thử Nmap, Hình 5.27

ID	Tài sản	Mối đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
				công tiếp theo	
T-02	Dịch vụ Node-RED	Truy cập trái phép	Dịch vụ HTTP không áp dụng cơ chế xác thực trong mô hình mô phỏng	Người không được phép có thể truy cập API cảm biến	Kiểm thử truy cập bằng curl, Hình 5.25
T-03	Hệ thống IDS Suricata	Bỏ sót tấn công mới	IDS sử dụng phương pháp Signature-based nên phụ thuộc vào tập luật	Có thể không phát hiện các kiểu tấn công chưa có chữ ký	Chương 2 - Signature-based IDS
T-04	Bộ luật Suricata	Bộ luật lỗi thời	Rule không được cập nhật thường xuyên	Giảm khả năng phát hiện các mối đe dọa mới	Cấu hình cập nhật ET Open, Hình 5.10 - Hình 5.12
T-05	Cấu hình pfSense	Cấu hình sai Firewall	Thiết lập Rule chưa phù hợp	Cho phép lưu lượng không mong muốn đi qua hệ thống	Cấu hình Firewall trong mô hình thực nghiệm
T-06	Nhật ký cảnh báo Suricata	Mất hoặc sửa đổi Alert Log	Nhật ký không được sao lưu hoặc bảo vệ	Gây khó khăn cho việc điều tra và phân tích sự cố	Alert Log Suricata, Hình 5.29

5.3. Ma trận rủi ro

Bảng 5.3. Ma trận rủi ro

ID	Khả năng (1–5)	Tác động (1–5)	Điểm	Mức rủi ro	Biện pháp	Rủi ro còn lại
R-01	4	3	12	Cao	Triển khai Suricata IDS để phát hiện hành vi quét cổng và theo dõi Alert Log.	Trung bình
R-02	3	4	12	Cao	Giới hạn quyền truy cập dịch vụ, bổ sung cơ chế xác thực cho Node-RED nếu triển khai thực tế.	Trung bình
R-03	2	5	10	Trung bình	Thường xuyên cập nhật bộ luật ET Open và kết hợp thêm các giải pháp phát hiện khác nếu cần.	Thấp
R-04	3	3	9	Trung bình	Thiết lập cơ chế cập nhật định kỳ bộ luật Suricata.	Thấp
R-05	2	5	10	Trung bình	Kiểm tra và rà soát các Firewall Rule trước khi đưa hệ thống vào hoạt động.	Thấp
R-06	2	3	6	Trung bình	Sao lưu Alert Log và kiểm tra định kỳ nhật ký sự kiện.	Thấp

5.4. Biện pháp giảm thiểu và ưu tiên

Bảng 5.4. Biện pháp giảm thiểu và ưu tiên

Mã rủi ro	Biện pháp giảm thiểu	Chủ thể thực hiện	Chi phí ước tính	Cách xác minh hiệu quả
R-01	Duy trì Suricata IDS để giám sát lưu lượng, cập nhật bộ luật ET Open định kỳ nhằm phát hiện hoạt động quét mạng.	Quản trị viên	Thấp	Thực hiện lại lệnh Nmap và kiểm tra Suricata sinh cảnh báo.

Mã rủi ro	Biện pháp giảm thiểu	Chủ thể thực hiện	Chi phí ước tính	Cách xác minh hiệu quả
R-02	Bổ sung cơ chế xác thực cho Node-RED, chỉ cho phép người dùng hợp lệ truy cập dịch vụ.	Quản trị viên	Thấp	Kiểm tra người dùng chưa xác thực không thể truy cập API.
R-03	Cập nhật thường xuyên bộ luật Suricata và theo dõi các phiên bản mới của ET Open.	Quản trị viên	Thấp	Kiểm tra trạng thái cập nhật và khả năng phát hiện sau khi cập nhật.
R-04	Thiết lập lịch kiểm tra và cập nhật bộ luật định kỳ.	Quản trị viên	Thấp	Xác nhận bộ luật được cập nhật theo kế hoạch và hệ thống hoạt động bình thường.
R-05	Rà soát và kiểm tra lại các Firewall Rule trước khi đưa hệ thống vào vận hành.	Quản trị viên	Thấp	Thực hiện kiểm thử lưu lượng hợp lệ và không hợp lệ qua Firewall.
R-06	Sao lưu Alert Log định kỳ và kiểm tra khả năng lưu trữ nhật ký.	Quản trị viên	Thấp	Kiểm tra Alert Log được lưu đầy đủ và có thể truy xuất khi cần.

5.5. Rủi ro còn lại

Mức độ rủi ro của hệ thống đã được giảm xuống so với thời điểm ban đầu sau khi áp dụng các biện pháp giảm thiểu. Hệ thống có khả năng phát hiện hoạt động quét mạng thông qua Suricata IDS, sao lưu nhật ký, kiểm tra cấu hình Firewall và các biện pháp cập nhật bộ luật góp phần nâng cao khả năng giám sát và quản lý an toàn thông tin.

Tuy nhiên hệ thống vẫn cần được theo dõi, cập nhật bộ luật phát hiện thường xuyên và kiểm tra định kỳ để duy trì hiệu quả khả năng phát hiện các mối đe dọa. Nhìn chung, mức rủi ro được đánh giá ở mức thấp đến trung bình, có thể chấp nhận đối với mục tiêu và phạm vi thực nghiệm của đề tài.

CHƯƠNG 6: KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

Đề tài đã triển khai mô hình hệ thống phát hiện xâm nhập mạng IoT dựa trên Suricata IDS trong môi trường ảo hóa VMware Workstation. Quy trình triển khai bao gồm xây dựng mô hình mạng, cấu hình pfSense làm Gateway và Firewall, mô phỏng dịch vụ IoT bằng Node-RED, triển khai Suricata IDS và thực hiện các kịch bản kiểm thử từ máy Kali Linux.

Về cơ bản đề tài đã triển khai được một hệ thống có khả năng giám sát lưu lượng mạng và phát hiện thành công hoạt động quét mạng bằng Nmap thông qua các cảnh báo Suricata. Song song với đó, đề tài cũng đã thực hiện đánh giá tài sản, phân tích mối đe dọa, đánh giá rủi ro và đề xuất các biện pháp giảm thiểu phù hợp với mô hình đã xây dựng. Nhìn chung, các mục tiêu đặt ra ban đầu đã được hoàn thành trong phạm vi đề tài. Mô hình thực nghiệm cho thấy tính khả thi của Suricata IDS trong giám sát an toàn mạng IoT.

6.1. Đối chiếu kết quả thực hiện với mục tiêu đề tài

Bảng 6.1. Bảng đối chiếu kết quả thực hiện với mục tiêu đề tài

Mã mục tiêu	Nội dung mục tiêu	Mức độ hoàn thành	Minh chứng
MT-01	Xây dựng mô hình mạng IoT mô phỏng phục vụ phát hiện xâm nhập	Hoàn thành	Chương 3 - Thiết kế và triển khai mô hình hệ thống
MT-02	Triển khai hệ thống phát hiện xâm nhập sử dụng Suricata IDS trên pfSense	Hoàn thành	Chương 4 - Cấu hình Suricata và pfSense
MT-03	Mô phỏng lưu lượng IoT bằng Node-RED và thực hiện các kịch bản kiểm thử	Hoàn thành	Chương 4 - Kết quả thực nghiệm
MT-04	Kiểm tra khả năng phát hiện hành vi quét cổng và ghi nhận cảnh báo của Suricata	Hoàn thành	Chương 4 - Kết quả kiểm thử Suricata
MT-05	Đánh giá khả năng hoạt động của mô hình thông	Hoàn thành	Chương 4 - Đánh giá kết quả

Mã mục tiêu	Nội dung mục tiêu	Mức độ hoàn thành	Minh chứng
	qua các kịch bản thử nghiệm		

6.2. Hạn chế

Hạn chế đầu tiên của đề tài là số lượng thiết bị tham gia còn ít và chưa mô phỏng được môi trường có nhiều thiết bị kết nối.

Thứ hai, Suricata hoạt động theo cơ chế phát hiện dựa trên tập luật. Vì vậy, khả năng phát hiện phụ thuộc vào các chữ ký số có sẵn và chưa nhận diện được những kiểu tấn công mới chưa được cập nhật trong bộ luật.

Thứ ba, Node-RED chỉ được dùng để mô phỏng việc cung cấp dữ liệu cảm biến thông qua giao thức HTTP. Do phạm vi của đề tài nên hệ thống chưa triển khai các giao thức IoT hoặc các tình huống trao đổi dữ liệu phức tạp khác.

Hạn chế cuối cùng, đề tài thực hiện một số kịch bản kiểm thử tiêu biểu như truy cập dịch vụ HTTP và quét cổng bằng Nmap. Các hình thức tấn công khác chưa được triển khai nên phạm vi đánh giá vẫn còn giới hạn.

6.3. Hướng phát triển

Ở tương lai, đề tài sẽ được mở rộng theo các hướng sau:

Xây dựng cơ chế giám sát và cảnh báo tập trung, đồng thời tự động cập nhật bộ luật Suricata, ngoài ra có thể áp dụng các chính sách ngăn chặn xâm nhập để nâng cao hiệu quả bảo vệ hệ thống. Mở rộng mô hình bằng cách bổ sung các thiết bị IoT hoặc cảm biến thực tế để đánh giá hệ thống trong môi trường gần với điều kiện triển khai thực tế hơn.

Nghiên cứu kết hợp cơ chế phát hiện dựa trên chữ ký (Signature-based IDS) với các phương pháp phát hiện dựa trên hành vi hoặc học máy nhằm nâng cao khả năng nhận diện các mối đe dọa mới chưa có chữ ký. Bổ sung các giao thức phổ biến như MQTT hoặc là CoAP nhằm đa dạng hóa kịch bản kiểm thử và đánh giá khả năng phát hiện của hệ thống.

TÀI LIỆU THAM KHẢO

- [1] Open Information Security Foundation (OISF). Suricata GitHub Repository. <https://github.com/OISF/suricata>. Branch: main. Truy cập ngày 19/07/2026. Phần sử dụng: Tham khảo mã nguồn, cấu trúc hệ thống IDS và bộ luật phát hiện xâm nhập Suricata.
- [2] Node-RED Project. Node-RED GitHub Repository. <https://github.com/node-red/node-red>. Branch: main. Truy cập ngày 20/07/2026. Phần sử dụng: Tham khảo mã nguồn và triển khai luồng xử lý dữ liệu IoT bằng Node-RED.
- [3] OWASP Foundation. OWASP IoT Security Testing Guide (ISTG). <https://github.com/OWASP/owasp-istg>. Branch: main. Truy cập ngày 10/07/2026. Phần sử dụng: Tham khảo phương pháp kiểm thử bảo mật cho hệ thống IoT.
- [4] OWASP Foundation. IoT Security Verification Standard (ISVS). <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>. Branch: master. Truy cập ngày 10/07/2026. Phần sử dụng: Tham khảo các yêu cầu và tiêu chuẩn bảo mật đối với hệ thống IoT.
- [5] Insecure.Org. Nmap GitHub Repository. <https://github.com/nmap/nmap>. Branch: master. Truy cập ngày 20/07/2026. Phần sử dụng: Tham khảo công cụ quét mạng và xây dựng kịch bản kiểm thử phát hiện xâm nhập.
- [6] Netgate. pfSense Documentation. <https://docs.netgate.com/pfsense/en/latest/>. Phiên bản: CE 2.7.x. Truy cập ngày 17/07/2026. Phần sử dụng: Tham khảo cấu hình tường lửa, giao diện mạng và định tuyến trên pfSense.